LabAid InsureTech Platform

System Requirements Specification (SRS)

Version: 3.10

Date: Dec 2025

Status: FINAL_DRAFT

Company: LabAid InsureTech

Technology Partner: LifePlus

Revision History

Version	Date	Revised By	Description
1.0	Dec 2025	Director InsureTech	Initial SRS with core business requirements
2.0	Dec 2025	Faruk Hannan	Technical architecture and detailed requirements with MD Sirs Feedback
2.2	Dec 2025	AI Engine	Enhanced Formatting, Grammar, Fact check
3.0	Dec 2025	Faruk Hannan	Final SPEC Draft with proto models, VSA architecture, and additional requirements
3.1	Dec 2025	Faruk Hannan	Final SPEC with MD Sirs Feedback M1.5 AI features and 10% Buffer -iteration1
3.2	Dec 2025	Faruk Hannan	Final SPEC with MD Sirs Feedback M1.5 AI features and 10% Buffer -iteration2
3.3	Dec 2025	Faruk Hannan	Final SPEC with MD Sirs Feedback M1.5 AI features and 10% Buffer -iteration3
3.4	Dec 2025	AI Engine	Formatting, Diagrams, Enhancements
3.5	Dec 2025	JOY, NOOR	Feedback and plan to spread out milestones
3.6	Dec 2025	SABBIR	Formatting
3.7	Dec 2025	FARUK HANNAN	reorganised priorities and added missing proto service definitions
3.8	Dec 2025	CEO (LifePlus), Director InsureTech , FARUK HANNAN, Dev Team , Business Head	Corrected some discussed points
3.9	Jan 2026	CEO (LifePlus), Director InsureTech , FARUK HANNAN, Dev Team , Business Head	Changed some requirements
3.10	Jan 2026	Sabbir	FR ID correction

Executive Summary

This System Requirements Specification (SRS) defines the functional and non-functional requirements of the LabAid InsureTech Platform — a cloud-native, microservices-based system enabling end-to-end digital insurance for the Bangladesh market. It covers onboarding and KYC, product discovery and quotation, policy lifecycle management, payments and reconciliation, claims management, reporting, and regulatory compliance.

The SRS is plan-agnostic and team-agnostic. It specifies what the system must do and the quality attributes it must meet, independent of delivery timelines, resource assignments, or milestone planning (captured in separate BRD/Planning documents).

Key themes

- Digital-first experience: Mobile and web channels with Bangladesh-optimized UX and language support.
- Compliance by design: IDRA/BFIU-aligned data, auditability, and reporting.
- Interoperability: Clear interfaces for identity/KYC, payments, messaging, and health systems.
- Security and privacy: Zero-trust posture, encryption, least-privilege authorization, and governed data handling.
- Observability and reliability: Logging, metrics, tracing, and service health for regulated operations.

Key changes in v3.7 (requirements-centric)

- Consolidated and de-duplicated functional requirements with continuous FR IDs.
- Expanded security and compliance requirements with cross-references.
- Proto-first interfaces organized by domain and included in appendices with examples.
- Clear separation of integration details under dedicated Integration section and references from FRs.

Phase Definitions:

- M1: March 1, 2025 (Soft Launch - National Insurance Day)
- M2: April 14th, 2025 (Grand Launch with critical features)
- M3: August 1, 2025 (Upgrade Release features)-----**LEMONADE V0.5**
- D: October 1, 2025 (Enhance Tech Release features)
- S: November 1, 2025 (Scaling features)
- F: January 1, 2027 (Expansion features)

Priority Levels:

- M1: Must have for M1 launch (Soft Launch)
- M2: Must have for M2 launch (Grand Launch)
- M3: Must have for M3 Enhancement
- D: Desirable features
- S: November 1, 2025 (Scalability)
- F: Future enhancements

Table of Contents

- Introduction
- System Overview
- System Architecture
- System Features & Functional Requirements
- User Interface Requirements
- Non-Functional Requirements
- Data Model & Persistence
- Security & Compliance Requirements
- Integration Requirements
- Performance & Monitoring
- Support & Maintenance
- Acceptance Criteria & Test Requirements
- Traceability Matrix & Change Control
- Appendices

1. Introduction

1.1 Purpose

This System Requirements Specification (SRS) document serves as the definitive technical blueprint for the LabAid InsureTech Platform. It provides comprehensive requirements for developers, testers, business analysts, and stakeholders to ensure successful delivery of a world-class digital insurance platform tailored for the Bangladesh market.

1.2 Scope

In Scope:

- Customer mobile application (Android, iOS)
- Customer web portal (React PWA)
- Partner portal (hospitals, MFS, e-commerce)
- Admin portal (multi-role: System Admin, Business Admin, Focal Person, Support)
- Backend microservices (Insurance Engine, Partner Management, AI Engine, Gateway, Kafka Orchestration, Ticketing, Analytics)
- Digital onboarding with KYC/KYB
- Product catalog and policy purchase
- Payment processing (bkash,nagad,rocket ,manual Phase 1, all channel automated +manual Phase 2)
- Claims submission and approval workflows (with basic check with AI Engine Phase 1, all channel automated +manual Phase 2)
- Partner management and tenant isolation
- Notification system (SMS, Email, Push)
- Reporting and analytics
- IDRA and BFIU compliance features
- Voice-assisted workflow (Bengali speech recognition, voice-guided policy purchase, voice claims submission)
- AI-based Claim Management (fraud detection, automated assessment, risk scoring)
- IoT-based Usage-Based Insurance (UBI) for vehicles and health tracking
- IOT based Tracking system

Out of Scope:

- Full AI-driven underwriting (Phase 2.5/3)
- Universal IoT/Telematics integration (Phase 2.5/3)
- Cross-border insurance (Future consideration)
- Blockchain-based smart contracts (Future consideration)

1.3 Definitions, Acronyms & Abbreviations

Term	Definition
IDRA	Insurance Development & Regulatory Authority of Bangladesh
BFIU	Bangladesh Financial Intelligence Unit
MFS	Mobile Financial Services (bKash, Nagad, Rocket)
KYC	Know Your Customer
AML	Anti-Money Laundering
CFT	Combating the Financing of Terrorism
gRPC	Google Remote Procedure Call
CQRS	Command Query Responsibility Segregation
VSA	Vertical Slice Architecture
Proto	Protocol Buffers
IoT	Internet of Things
AI	Artificial Intelligence
ML	Machine Learning
API	Application Programming Interface
SLA	Service Level Agreement
TAT	Turn Around Time
EHR	Electronic Health Records
OCR	Optical Character Recognition
SMS	Short Message Service
OTP	One-Time Password
JWT	JSON Web Token
RBAC	Role-Based Access Control

Business Terms:

- Policyholders: Individual customers who purchase insurance policies
- Partners: System-onboarded, collaborative organizations (MFS, hospitals, e-commerce)
- Agents: Individual sales representatives working with partners
- Focal Persons: Partner organization representatives managing agent networks
- Sum Assured: Maximum coverage amount for a policy
- Premium: Insurance policy cost paid by policyholder
- Claims: Requests for insurance payouts due to covered incidents
- Underwriting: Risk assessment process for policy approval
- Reinsurance: Insurance purchased by insurance company to limit risk

2. System Overview

2.1 Business Context

The LabAid InsureTech Platform addresses the significant insurance gap in Bangladesh, where traditional insurance penetration remains below 1% of GDP. Our platform focuses on micro-insurance products (200-2,000 BDT premiums) to make insurance accessible to the mass market through digital channels and strategic partnerships.

Market Opportunity:

- Target Market: 165+ million Bangladeshi citizens with mobile phones
- Insurance Gap: 99% of population lacks adequate insurance coverage
- Digital Adoption: 50%+ smartphone penetration with growing digital payment usage
- Regulatory Support: IDRA's digital insurance initiatives and sandbox programs

Business Model:

- B2B Approach: Partner with MFS providers, hospitals, e-commerce platforms
- B2C Approach: Making Microinsurance products affordable for average Bangladeshi families
- Commission-Based Revenue: 15-25% commission on premium collections
- Value-Added Services: IoT risk assessment, AI-powered customer support
- Data Monetization: Anonymized insights for partners (IDRA compliant)

2.2 System Objectives

Primary Objectives:

- Digital Insurance Ecosystem: End-to-end digital insurance journey from discovery to settlement
- Mass Market Accessibility: Micro-insurance products affordable for average Bangladeshi families
- Partner Network Growth: Scalable platform supporting 100+ partners and 10,000+ agents
- Regulatory Excellence: Full IDRA and BFIU compliance with automated reporting
- Operational Efficiency: 90%+ automated processes with minimal manual intervention

Success Metrics:

- Policy Issuance: 10,000 policies/month by Month 6
- Claims Settlement: 95% claims settled within 72 hours
- Customer Satisfaction: 4.5+ star rating on app stores
- Partner Growth: 50+ active partners by Year 1
- Revenue Target: 10 Crore BDT annual premium by Year 2

2.3 Key Stakeholders

Internal Stakeholders:

- Business Executives: Strategic oversight and P&L responsibility
- Product Management: Feature prioritization and roadmap planning
- Technology Leadership: Architecture and development oversight

- Compliance Team: Regulatory adherence and audit management
- Customer Success: Partner relationship and customer experience

External Stakeholders:

- IDRA: Regulatory approval and ongoing compliance monitoring
- Partners: MFS providers, hospitals, e-commerce platforms
- Customers: Individual policyholders and their families
- Technology Vendors: Cloud providers, payment gateways, third-party services

2.4 System Boundaries

System Includes:

- Insurance policy lifecycle management
- Customer onboarding and KYC verification
- Premium collection and payment processing
- Claims submission, assessment, and settlement
- Partner and agent management
- Regulatory reporting and compliance
- Customer support and AI assistance

System Interfaces:

- Mobile applications (Android/iOS)
- Web portals (customer, partner, admin)
- REST and gRPC APIs for integrations
- Payment gateway connections
- Government database integrations (NID, mobile verification)
- Third-party services (SMS, email, cloud storage)

External Dependencies:

- Bangladesh government services (NID verification, mobile number validation)
- Payment providers (bKash, Nagad, banks)
- Cloud infrastructure (AWS/Azure)
- Regulatory reporting systems
- Partner systems and databases

3. System Architecture

3.1 Architectural Overview

The LabAid InsureTech Platform is built on a cloud-native, microservices architecture with Domain-Driven Design (DDD) principles. The system leverages Vertical Slice Architecture (VSA) pattern across all services for maximum cohesion and maintainability.

Core Architectural Principles:

- Microservices First: Independent, deployable services with single responsibilities
- Event-Driven Architecture: Asynchronous communication through domain events
- API-First Design: All services expose well-defined APIs (REST/gRPC)
- Cloud-Native: Built for containerization and orchestration
- Security by Design: Zero-trust security model with end-to-end encryption

3.2 Technology Stack

Languages & Frameworks:

- Go: Gateway, Authentication, Authorization, DBManager, Storage, IoT Broker, Kafka Services
- C# .NET 8: Insurance Engine, Partner Management, Analytics & Reporting
- Node.js: Payment Service, Ticketing/Support Service
- Python: AI Engine, OCR/PDF Processing
- React: All web portals and admin interfaces
- React Native: Mobile applications (Android/iOS)

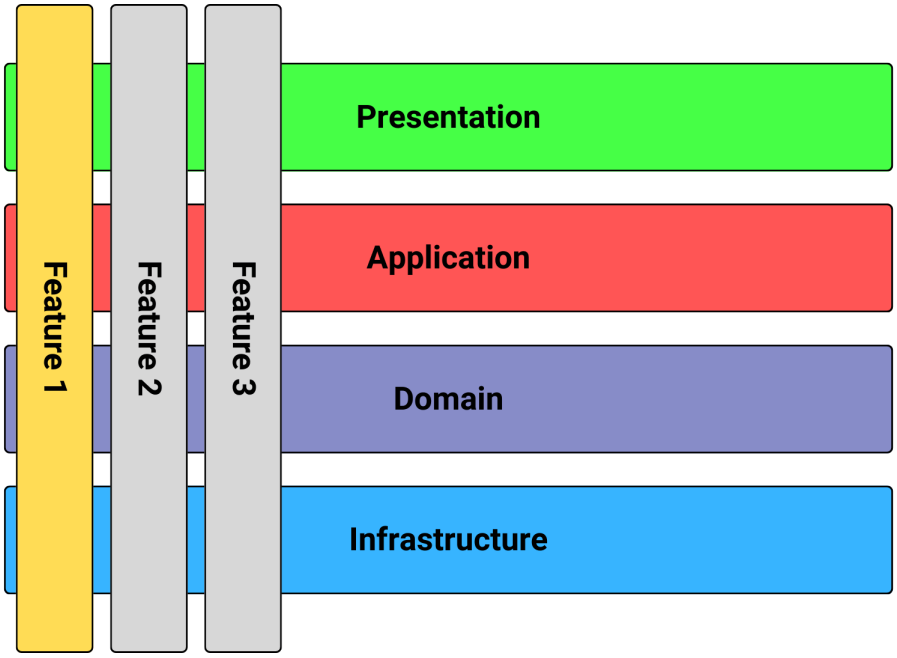
Data & Communication:

- Protocol Buffers: All data models and service contracts
- PostgreSQL: Primary database for transactional data
- MongoDB: NoSQL for product catalogs and unstructured data
- Apache Kafka: Event streaming and service orchestration
- gRPC: Inter-service communication
- REST APIs: Client-facing and partner integrations

Infrastructure:

- Docker: Containerization
- Kubernetes: Container orchestration
- AWS/Azure: Cloud platform
- Prometheus/Grafana: Monitoring and alerting
- Jaeger: Distributed tracing
- Redis: Caching and session management

3.3 System Architecture - VSA Pattern



VSA Architecture

Figure 1: Vertical Slice Architecture - Language-Agnostic Pattern

The LabAid InsureTech Platform adopts Vertical Slice Architecture (VSA) across ALL microservices, regardless of programming language:

- Go Services: Gateway, Auth, DBManager, Storage, IoT Broker, Kafka Orchestration
- C# .NET Services: Insurance Engine, Partner Management, Analytics & Reporting
- Node.js Services: Payment Service, Ticketing Service
- Python Services: AI Engine, OCR/PDF Service

Key VSA Principles:

- High Cohesion: Each slice contains all layers needed for one feature
- Low Coupling: Slices are independent and don't share logic
- Feature-Focused: Organized by business capability, not technical layer
- Testability: Each slice can be tested in isolation

3.4 Microservices Architecture

Service Inventory:

Service	Language	Port	Responsibility
Gateway	Go	8080	API Gateway, routing, rate limiting
Auth Service	Go	8081	Authentication, JWT management
Authorization	Go	8082	RBAC, permissions, access control
DBManager	Go	8083	Database operations, migrations
Storage Service	Go	8084	File storage, S3 operations
IoT Broker	Go	8085	IoT device communication, MQTT
Kafka Service	Go	8086	Event orchestration, messaging
Insurance Engine	C# .NET	5001	Policy lifecycle, underwriting
Partner Management	C# .NET	5002	Partner onboarding, agent mgmt
Analytics & Reporting	C# .NET	5003	BI, dashboards, compliance reports
Payment Service	Node.js	3001	Payment processing, settlements
Ticketing Service	Node.js	3002	Customer support, help desk
AI Engine	Python	4001	LLM, chatbot, fraud detection
OCR Service	Python	4002	Document processing, KYC

3.5 System Context Diagram

```
+----------------------------+            +---------------------------------+
|       External Systems     |            |     User Interfaces (Clients)    |
| - MFS (bKash/Nagad/Rocket) |<---------->| - Web (React PWA)                |
| - Hospital EHR (FHIR/HL7)  |  HTTPS/    | - Mobile (React Native)          |
| - NID Verification API     |  REST/     | - Partner/Admin Portals (React)  |
| - IDRA / BFIU Portals      |  gRPC/WS   | - Ops/Observability (Graf/Prom)  |
| - SMS / Email Gateway      |            +---------------------------------+
+----------------------------+
                 |
                 v
+-------------------------------------------------------------+
|                  API & Integration Layer                    |
|   - API Gateway (Go): routing, rate-limit, authN            |
|   - Auth Service (Go): OAuth2/OIDC, JWT, RBAC (authZ)       |
|   - Kafka (Go): domain events & async orchestration         |
+-------------------------------------------------------------+
                 |
                 | gRPC (Protobuf)  <-->  Kafka Events
                 v
+-------------------------------------------------------------+
|           Backend Microservices (VSA + gRPC)                |
|   - Insurance Engine (C# .NET, CQRS/MediatR)                |
|   - Partner/Agent Mgmt (C# .NET)                            |
|   - Analytics & Reporting (C# .NET)                         |
|   - Payment Service (Node.js)                               |
|   - Ticketing/Support (Node.js)                             |
|   - AI Engine (Python, LLM/Fraud)                           |
|   - OCR/PDF Service (Python)                                |
|   - DBManager (Go)        - Storage (Go, S3/Object)         |
|   - IoT Broker (Go, MQTT/gRPC)                              |
+-------------------------------------------------------------+
                 |
                 v
+-------------------------------------------------------------+
|                        Data Layer                           |
|   - PostgreSQL 17 (Transactional, ACID)                     |
|   - MongoDB (Unstructured)  - Redis (Cache/Sessions)        |
|   - S3/Object Storage (Documents, Images)                   |
+-------------------------------------------------------------+
```

Key Architectural Highlights:

- Multi-Language Microservices: Go, C#, Node.js, Python - all communicate via gRPC
- Event-Driven: Kafka for asynchronous communication and event sourcing
- VSA Pattern: Each service implements vertical slices internally
- CQRS: Insurance Engine uses Command Query Responsibility Segregation
- Reusable Services: 755 hours of production-tested code (Gateway, Auth, DBManager, Storage, IoT)

4. System Features & Functional Requirements

This section defines all functional requirements organized by feature groups, with phased delivery approach aligned to the team capacity and project milestones.

Phase Definitions:

- M1: March 1, 2025 (Soft Launch - National Insurance Day)
- M2: April 14th, 2025 (Grand Launch with critical features)
- M3: August 1, 2025 (Upgrade Release features)
- D: October 1, 2025 (Enhance Tech Release features)
- S: November 1, 2025 (Scaling features)
- F: January 1, 2027 (Expansion features)

Priority Levels:

- M1: Must have for M1 launch (Soft Launch)
- M2: Must have for M2 launch (Grand Launch)
- M3: Must have for M3 Enhancement
- D: Desirable features
- S: November 1, 2025 (Scalability)
- F: Future enhancements

Core Foundation

4.1 User Management & Authentication (FG-001)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-001	The system shall support phone-based registration (Bangladesh mobile format: +880 1XXX XXXXXX) with OTP validation.User will get the option to login as Corporate ID and Individual phone number.User can use the same phone number against the corporate profile and individual profile.	M1	OTP sent within 60s, 6-digit code valid for 5 minutes
FR-002	The system shall send OTP via SMS within 60 seconds with 6-digit code valid for 5 minutes.We will not ask user for OTP every time.	M1	95% delivery success rate, retry on failure
FR-003	The system shall allow maximum 3 OTP resend attempts per 15-minute window	M1	Rate limiting enforced, user notified on limit
FR-004	The system shall enforce unique mobile number per account and detect duplicate registrations. Mobile number will be unique.Family dependent max 6 members can be added.	M1	Error message on duplicate, database constraint enforced

FR-005	The system shall support email-based registration with email verification link (24-hour validity)	M2	Verification email sent within 2 minutes, link expires after 24hrs
FR-006	The system shall implement secure password policy: minimum 8 characters, 1 uppercase, 1 number, 1 special character	M1	Password strength indicator shown, validation enforced
FR-007	The system shall provide biometric authentication (fingerprint/face ID) for mobile users	D	Device biometric API integration, fallback to password
FR-008	The system shall support password reset via OTP to registered mobile number	M1	Reset OTP sent within 60s, new password saved securely
FR-009	The system shall implement session management with Secure Token Service (15-minute access, 7-day refresh)	M1	Token rotation implemented, refresh token stored securely
FR-010	The system shall enforce account lockout after 5 failed login attempts for 30 minutes	M2	Lockout triggered automatically, user notified via SMS
FR-011	The system shall maintain user profile with: full name, date of birth, gender, occupation, address.User can switch profile from Corporate to Individual and vise versa	M1	All mandatory fields validated, profile completeness indicator
FR-012	The system shall support profile photo upload with validation (max 5MB, JPEG/PNG, face detection)	M3	Image compressed to <2MB, face detection validates single face
FR-013	The system shall have stakeholders registration via SAML Identity provider	D	SAML 2.0 integration with Azure AD/Okta, SSO enabled

4.2 Authorization & Access Control (FG-002)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-014	The system shall implement Role-Based Access Control (RBAC) with predefined roles: System Admin, Business Admin, Focal Person, Partner Admin, Agent, Customer	M1	Roles enforced at API gateway level, permissions validated on each request
FR-015	The system shall enforce Attribute-Based Access Control (ABAC) for fine-grained permissions based on user attributes, resource type, and context	M1	Dynamic policy evaluation <50ms, audit logs for all authorization decisions
FR-016	The system shall implement tenant isolation for partner organizations with data segregation	M2	Multi-tenant database architecture, row-level security enforced
FR-017	The system shall enforce 2FA (Two-Factor Authentication) for all admin-level access	M3	TOTP-based 2FA with 30-second rotation, backup codes provided
FR-018	The system shall maintain Access Control Lists (ACL) for resource-level permissions	M1	ACL stored in database, cached in Redis for performance

FR-019	The system shall implement hierarchical role inheritance (Partner Admin > Agent > Customer)	D	Child roles inherit parent permissions, override capability available
FR-020	The system shall provide permission audit trail for all sensitive operations	M3	Immutable audit logs, queryable by role/user/action/timestamp

Product & Policy Lifecycle

4.3 Product Management & Catalog (FG-003)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-021	The system shall provide product catalog with categorization: Health, Life, Motor, Travel, Micro-insurance . Preference will be- Health -> Auto ->Travel -> Life	M1	Products displayed by category, search and filter enabled
FR-022	The system shall support product search by name, category, coverage type, and premium range	M1	Search results <500ms, fuzzy matching for Bengali text
FR-023	The system shall display product details: coverage, premium, tenure, exclusions, terms & conditions	M2	All product information visible before purchase, PDF download available
FR-024	The system shall provide premium calculator with dynamic inputs (age, sum assured, tenure, riders)	M3	Real-time calculation <2s, breakdown of premium components shown
FR-025	The system shall support product comparison (side-by-side up to 2 products)	M3	Comparison table with key features, coverage, and pricing
FR-026	The system shall enable Business Admin to create, update, and deactivate products	M1	Product CRUD operations, version history maintained
FR-027	The system shall support product variants with configurable riders and add-ons. Coverage can be increased for addons existing with B2B product.	D	Base product + optional riders, dynamic pricing recalculation
FR-028	The system shall cache product catalog in Redis with 5-minute TTL for performance	M3	Cache hit rate >80%, automatic invalidation on product updates
FR-029	The system shall support multi-language product descriptions (Bengali and English)	M3	Language toggle in UI, content stored in i18n format

4.4 Policy Lifecycle Management (FG-004)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-030	The system shall support end-to-end policy purchase flow: product selection → applicant details → nominee details → payment → policy issuance	M1	Complete flow in <10 minutes, progress saved at each step
FR-031	The system shall collect applicant information: full name, DOB, NID(optional), address, occupation, income, health declaration	M1	All mandatory fields validated, conditional fields based on product type
FR-032	The system shall support Single nominee/beneficiary	M1	Only 1 nominee required
FR-033	The system shall validate NID/Mobile Number uniqueness across policies to prevent duplicate insurance	M1	Database constraint enforced, user notified of existing policies
FR-034	The system shall generate unique policy number with format: LBT-YYYY-XXXX-NNNNNN. For example: InsuranceType-Insurer-NumericID(Product)	M1	Sequential numbering, year-based prefix, collision prevention
FR-035	The system shall issue digital policy document (PDF) with QR code for verification	M2	PDF generated within 30s of payment confirmation, QR code scannable
FR-036	The system shall send policy document via SMS link and email attachment	M2	Delivery within 5 minutes, retry mechanism on failure
FR-037	The system shall activate policy immediately upon payment confirmation for instant coverage(Non Life)	M2	Policy status updated in real-time, customer notified
FR-038	The system shall support policy cooling-off period (5 days from issuance) for full refund	M3	Cancellation request processed within 24hrs, refund initiated
FR-039	The system shall maintain policy status: Pending Payment, Active, Suspended, Cancelled, Lapsed, Expired	M1	Status transitions logged with timestamp, notifications triggered
FR-040	The system shall provide customer policy dashboard showing all active and past policies, renewal prompts, and premium payment history	M1	Dashboard loads <3s, real-time status updates
FR-041	Users will be able to see order history. Under the Order history screen user will get option to view Coverage details , Refer , Active Plans , Claimed Plans and Expired plans.Users will get the option to Refer the policy after purchasing any insurance package.Referral Count will should be shown with the users.Max Referral limit 1 .User will get option for purchase and download the certificate	D	

4.5 Policy Management & Renewals (FG-005)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-042	The system shall implement 'Family Insurance Wallet' allowing users to group and manage policies for multiple family members under one account	D	Unified dashboard, single-click bulk payment, relationship management
FR-043	The system shall send renewal reminders: 30 days, 7 days, 1 day before expiry via SMS, email, push notification	M2	Notifications sent on schedule, delivery confirmation tracked
FR-044	The system shall support manual policy renewal with one-click process reusing existing policy data	M2	Renewal completed in <3 minutes, updated policy document issued
FR-045	The system shall support automatic policy repurchase with stored payment method (opt-in by customer)	M3	Customer consent recorded, auto-charge 7 days before expiry
FR-046	The system shall allow customer to update policy details during renewal: current address, nominee information	M3	Limited fields editable, verification required for major changes
FR-047	The system shall implement grace period (30 days) for premium payment post-expiry with continued coverage	M2	Policy status "Grace Period", coverage continues, daily reminders
FR-048	The system shall auto-lapse policy after grace period if payment not received, with reinstatement option	M2	Policy status "Lapsed", reinstatement within 90 days with penalty
FR-049	The system shall provide policy document download (PDF) with version history for all renewals	M1	All versions accessible, clearly marked with issue date
FR-050	The system shall track policy lifecycle events: issuance, renewal, lapse, reinstatement, cancellation with audit trail	M1	Immutable event log, queryable by date range and policy number

4.5.1 Policy Cancellation & Refund

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-051	The system shall support policy cancellation workflow with cancellation request submission by customer/agent/admin	M1	Request form with reason dropdown, attachment support
FR-052	The system shall implement approval workflow for policy cancellation: Business Admin + Focal Person approval required for policies >30 days old	M1	Approval routing, 48hr SLA
FR-053	The system shall calculate pro-rata refund: (Premium Paid - Days Covered - Admin Fee - Cancellation Charge) with transparent breakdown	M1	Refund calculator, configurable fees
FR-054	The system shall process refund within 7 working days via MFS or bank transfer	M1	Payment gateway integration, notifications
FR-055	The system shall update policy status to CANCELLED and notify all stakeholders	M1	Multi-channel notification, IDRA reporting

4.5.2 Policy Endorsement & Amendment

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-056	The system shall support policy endorsement for: Address, Sum insured, Nominee, Contact changes	M1	Amendment forms, validation
FR-057	The system shall calculate additional premium for mid-term sum insured increases	D	Premium calculator, payment integration
FR-058	The system shall calculate pro-rata refund for sum insured decreases	M2	Credit to premium account
FR-059	The system shall generate endorsement document with suffix (PLN-001/END-01)	M1	PDF generation, version tracking
FR-060	The system shall require approval for sum insured changes >10%	M1	Approval workflow, threshold config

4.6 Business Rules & Workflows (FG-06)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-061	The system shall implement premium calculation fallbacks: If insurer API fails, use cached rates (max 24hrs old); if unavailable, queue quote and notify customer within 2 hours(**Bimafy as example**)	M1	• Fallback logic tested • Cache validation • Queue notification works
FR-062	The system shall handle premium calculation edge cases: age-based loading, occupation risk factors, pre-existing conditions with clear messaging	M2	• All edge cases covered • Messaging user-friendly • Actuarial validation
FR-063	The system shall implement duplicate policy detection: Block duplicate policy purchase for same product + same insured person within 30 days; allow cross-product purchases	M1	• Detection accurate • Cross-product allowed • Clear error message
FR-064	The system shall enable policy merge workflow: Focal Person can merge duplicate accounts after verifying NID, transfer policies, consolidate claims history	M3	• Merge workflow tested • Data integrity maintained • Audit logged
FR-065	The system shall define claim status state machine: Submitted → Under Review → Documents Requested → Approved/Rejected → Payment Initiated → Settled/Closed	M1	• State machine implemented • Invalid transitions blocked • Status tracking accurate
FR-066	The system shall enforce claim status transition rules: Auto-move to "Documents Requested" if incomplete; require Business Admin+Focal Person approval for >BDT 50K	M1	• Transition rules enforced • Approval routing correct • Notifications sent
FR-067	The system shall implement gamified renewal rewards program offering discounts or gift vouchers for early renewals	D	Points calculation engine, partner voucher integration, leaderboard
FR-068	The system shall implement grace period logic: 30-day grace period post-expiry with coverage continued; auto-lapse if unpaid after grace period	M3	• Grace period enforced • Coverage continued • Auto-lapse works • Customer notified
FR-069	The system shall enable lapsed policy reinstatement: Allow reinstatement within 90 days of lapse with medical underwriting; require Focal Person approval	D	• Reinstatement workflow • Medical underwriting integrated • Approval required

Financial Operations

4.7 Payment Processing (FG-007)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-070	The system shall support multiple payment methods: bKash, Nagad, Rocket, Bank Transfer, Credit/Debit Card	M1	All MFS integrated, card via hosted payment page, manual verification
FR-071	The system shall integrate bKash payment gateway with production credentials and sandbox for testing	M1	Transaction success rate >99%, fallback to manual on failure
FR-072	The system shall integrate Nagad and Rocket MFS with tokenization for recurring payments	M3	Secure token storage, PCI-DSS Level SAQ-A compliance
FR-073	The system shall support manual payment with proof upload (bank receipt, bKash screenshot) for verification	M1	Image upload <5MB, admin verification within 24hrs
FR-074	The system shall implement payment verification workflow: pending → verified → policy activated OR rejected → refund	M2	Admin approval for manual payments, automated for MFS
FR-075	The system shall generate payment receipt with transaction ID, amount, date, policy number	M2	PDF receipt sent via SMS/email within 5 minutes
FR-076	The system shall support partial payment and installment plans for high-premium policies (Monthly,quarterly, half-yearly, annual)	M3	Auto-reminders before due date, grace period 15 days
FR-077	The system shall implement payment retry mechanism with exponential backoff for failed transactions	M2	Max 3 retries, customer notified on each attempt
FR-078	The system shall support refund processing for policy cancellation with configurable refund rules	M2	Refund initiated within 7 days, credited to original payment method
FR-079	The system shall integrate TigerBeetle for financial transaction recording with double-entry bookkeeping	M2	All transactions recorded, real-time balance reconciliation
FR-080	The system shall maintain payment audit trail with immutable logs for regulatory compliance(**CFO /Finance dependency**)	M1	PostgreSQL + S3 storage, 20-year retention

Claims Management

4.8 Claims Management (FG-008)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-081	The system shall provide fixed-step claim submission form: policy selection, incident details, claim reason, document upload (images, bills, reports).Claim tracker must be shown.	M1	Form completion <5 minutes, draft saving at each step
FR-082	The system shall validate claim eligibility: policy active, within coverage period, claim type covered, no duplicate submission	M1	Validation in <3s, clear error messages on rejection
FR-083	The system shall generate unique claim number with format: CLM-YYYY-XXXX-NNNNNN and digital hash for submission integrity	M1	Collision-free numbering, SHA-256 hash for document integrity
FR-084	The system shall automatically notify partner/insurer upon claim submission with shared status dashboard	M2	Notification within 60s, dashboard accessible to all stakeholders
FR-085	The system shall provide real-time claim status tracking: Submitted, Under Review, Approved, Rejected, Settled.Customer should notify through push notification and SMS	M3	Status updates visible in <5s, push notifications on status change
FR-086	The system shall implement tiered approval workflow based on claim amount as per Approval Matrix	M3	Auto-routing to correct approver, escalation on timeout
FR-087	The system shall support document verification with image quality check, OCR extraction, and fraud detection	M3	Image validation <10s, OCR accuracy >85%, duplicate detection
FR-088	The system shall provide chat interface between customer, partner agent, and focal person for claim discussion	M3	Real-time messaging, file attachment support, message history
FR-089	The system shall support WebRTC video call for claim verification and inspection	D	HD video quality, screen sharing, call recording for audit
FR-090	The system shall allow partner to add verification notes and approve/reject with reason	M2	Notes timestamped, approval requires mandatory reason field
FR-091	The system shall enforce joint approval by Business Admin and Focal Person for claims BDT 50K-2L(**Only insurance company will provide Approval**)	M3	Both approvals required, timeout escalation after 5 days

FR-092	The system shall automate payment process upon claim approval as per customer's selected payment channel	M3	Payment initiated within 24hrs, confirmation sent to customer
FR-093	The system shall support Zero Human Touch Claims (ZHTC) for auto-verification and payment of small claims (<BDT 10K) with partner pre-agreement	D	95% automation rate, ML-based fraud check, instant settlement
FR-094	The system shall implement fraud detection: frequent claims (>3 in 6 months), duplicate documents, rapid policy-to-claim (<48hrs)	M3	Auto-flagging with risk score, manual review queue, customer warning system
FR-095	The system shall auto-revoke customer access for confirmed fraud as per InsureTech policy	M3	Account suspension after approval, appeal process available
FR-096	The system shall maintain balance sheet on Customer, Partner, Agent, and InsureTech level for selected time periods	M3	Daily, monthly, quarterly reconciliation, export to Excel/PDF
FR-097	The system shall track Turn Around Time (TAT) per approval level and alert on SLA breach	M3	Real-time TAT monitoring, email alerts on approaching deadline
FR-098	The system shall provide claim history and analytics for risk assessment and premium adjustment	M3	Claim frequency report, average claim amount, settlement ratio

Claims Approval Matrix:(Only For Insurance Company)

Claimed Amount	Approval Level	Approver(s)	Maximum TAT
BDT 0-10K	L1 Auto/Officer	System Auto-Approval OR Claims Officer	24 Hours
BDT 10K-50K	L2 Manager	Claims Manager	3 days
BDT 50K-2L	L3 Head	Business Admin + Focal Person (Joint)	7 days
BDT 2L+	Board	Board + Insurer Approval	15 days

4.8.1 Claims Document Requirements & Processing

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-099	The system shall enforce claims document requirements: PDF/JPG/PNG, max 10MB per file, 50MB total per claim, 300 DPI minimum	M1	Client-side validation, OCR quality check
FR-100	The system shall calculate co-payment and deductibles: (Claim Amount - Deductible) × Co-payment % with annual deductible tracking	M1	Product-level config, breakdown display
FR-101	The system shall support claims reimbursement workflow with document review and bank/MFS transfer within 7-15 working days(**It will handle by insurance company**)	M1	Document verification, payment processing, status notifications

Partner Ecosystem

4.9 Partner & Agent Management (FG-009)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-102	The system shall support partner onboarding workflow: application submission, KYB verification, MOU upload, approval by Focal Person	M2	Complete onboarding in <7 days, status tracking at each step
FR-103	The system shall collect partner information: organization name, type (hospital/MFS/e-commerce/agent), trade license, TIN, bank account, contact details	M2	All mandatory fields validated, document verification required
FR-104	The system shall implement KYB (Know Your Business) verification with trade license validation and credit check	M2	Automated validation where possible, manual review for exceptions
FR-105	The system shall provide dedicated partner portal with dashboard showing: leads, conversions, commissions, analytics	M2	Dashboard loads <3s, real-time data updates, export functionality
FR-106	The system shall calculate and track partner commissions based on configurable rates (acquisition, renewal, claims assistance)	M2	Commission calculated on policy activation, monthly payout reports
FR-107	The system shall support partner API integration for embedded insurance (e-commerce checkout, hospital admission)	M3	RESTful API with sandbox, developer documentation, webhook support
FR-108	The system shall enable partner to initiate policy purchase on behalf of customer with consent and authentication	M2	Customer OTP verification required, policy linked to customer account
FR-109	The system shall provide Focal Person portal for partner management: verification, approval, dispute resolution, performance monitoring	M1	Full CRUD operations on partners, approval workflow, audit trail
FR-110	The system shall support multi-level agent hierarchy under partners (Partner Admin > Regional Manager > Agent)	M3	Hierarchical commission split, territory management, performance tracking
FR-111	The system shall track partner performance metrics: policies sold, claim settlement ratio, customer satisfaction, fraud incidents	M2	Weekly/monthly reports, performance scoring, alerts on anomalies
FR-112	The system shall support partner suspension/termination with graceful policy transfer mechanism	M2	Existing policies remain active, new

			sales blocked, customer notification

4.9.1 Stakeholder Hierarchy & Focal Person Role

```
System Admin (Cloud/IAM Root)
    │
    ├── Repository Admin (Code/Deploy)
    │
    ├── Database Admin (Data Management)
    │
    ├── Business Admin (Business Operations)
    │   │
    │   └── Focal Person (Partner Bridge) ★ KEY ROLE
    │       │
    │       └── Partner Admin (Tenant Root)
    │           │
    │           ├── Insurer Agents (Partner Staff)
    │           └── Insurer Underwriters (API Users)
    │
    ├── Dev (Development)
    │
    └── Support/Call Centre (Customer Assistance)
```

Focal Person Role Requirements:

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-113	Focal Person shall have authority to verify and approve/reject partner applications within 3 business days	M1	Decision recorded with reason, partner notified automatically
FR-114	Focal Person shall monitor partner compliance and flag suspicious activities for investigation	M2	Real-time dashboard with alerts, escalation to Business Admin
FR-115	Focal Person shall resolve partner-customer disputes with documented decision trail	M2	Dispute resolution within 7 days, audit log maintained

4.10 Partner Portal & Business Intelligence (FG-010)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-116	The system shall provide hospital partners special dashboard to initiate insurance purchase on behalf of customers	M2	Patient data prefill from hospital system, consent capture
FR-117	The system shall support API for transferring customer records with authentication token and purchase ID	D	RESTful API with OAuth2, data mapping documentation
FR-118	The system shall provide e-commerce partners embedded widget for insurance product display at checkout	M2	JavaScript SDK, responsive design, cart integration
FR-119	The system shall provide sandbox environment for 3rd party developers with test credentials and mock data	D	Isolated test environment, sample code, API documentation
FR-120	The system shall provide partner analytics: leads generated, conversion rate, commission earned, customer feedback	M2	Dashboard with filters, trend charts, export to Excel/PDF
FR-121	The system shall provide partner API for retrieving analytics and commission statements programmatically	D	RESTful API, pagination support, webhook for new data
FR-122	The system shall implement Business Intelligence tool (Metabase/Tableau/Power BI) for advanced analytics	F	Read replica connection, pre-built dashboards, scheduled reports
FR-123	The system shall provide executive dashboard: daily sales, policy count, claims ratio, revenue, system health	M2	Real-time data, drill-down capability, mobile-responsive
FR-124	The system shall provide partner-specific branding capability for white-label insurance offerings	F	Custom logo, colors, domain mapping, isolated tenant data
FR-125	The system shall enable partners to configure commission structures and incentive programs	D	Tiered commission, bonus rules, performance-based adjustments
FR-126	The system shall log all API requests with payload, headers, timestamps	M2	Structured logging, rotation, searchable
FR-127	The system shall implement distributed tracing across microservices	D	Jaeger integration, trace ID propagation

Customer Service & Engagement

4.11 Customer Support & Helpdesk (FG-011)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-128	The system shall provide in-app FAQ section with searchable knowledge base covering common queries(hot line number :8801766662772)	M1	Search results <1s, categorized by topic, Bengali and English
FR-129	The system shall support customer support call initiation from mobile app with call recording	M3	Click-to-call integration, call routing to available agent
FR-130	The system shall implement ticketing system for customer issues with unique ticket ID and status tracking	M2	Ticket creation <30s, status updates via notification
FR-131	The system shall provide support agent portal with ticket queue, customer history, and resolution templates	M2	Agent dashboard loads <3s, SLA countdown visible
FR-132	The system shall auto-record customer support calls and create ticket with call summary	M3	Speech-to-text transcription, auto-tag issue category
FR-133	The system shall track support metrics: average response time, resolution time, customer satisfaction score	M2	Real-time dashboard, weekly reports to management
FR-134	The system shall support escalation workflow: Tier 1 (Support) → Tier 2 (Technical) → Tier 3 (Engineering)	M2	Auto-escalation after 24hrs unresolved, notification sent
FR-135	The system shall provide customer feedback form after ticket resolution with 5-star rating	M2	Feedback collected, low ratings flagged for review

4.12 Notifications & Communication (FG-012)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-136	The system shall implement Kafka event-driven notification system with multiple channels: in-app push, SMS, email	M1	Event published within 100ms, delivery to all channels coordinated
FR-137	The system shall send notifications for: OTP, verification, purchase confirmation, claims updates, renewal reminders, payment confirmations	M1	Template-based messages, personalized with customer data
FR-138	The system shall support notification preferences with opt-in/opt-out for marketing and promotional messages	M2	User preferences stored, GDPR-compliant consent management
FR-139	The system shall implement customer mute mode with minimum text notification (avoiding push for low-end devices)	M2	Device capability detection, graceful degradation
FR-140	The system shall allow partners to create secondary marketing notifications filtered by: age, gender, location, policy type	M3	D
FR-141	The system shall track notification delivery status: queued, sent, delivered, failed, bounced with retry mechanism	M2	Real-time status tracking, max 3 retries with exponential backoff
FR-142	The system shall support message templates with dynamic placeholders for personalization	M2	Template engine with Bengali/English support, variable substitution
FR-143	The system shall implement rate limiting for notifications to prevent spam (max 5 per hour per user)	M3	Redis-based rate limiting, exception for critical alerts
FR-144	The system shall provide notification history in customer dashboard with read/unread status	M3	Last 90 days visible, older notifications archived
FR-145	The system shall support rich push notifications with images, action buttons, and deep links	D	Platform-specific implementation (iOS/Android), click tracking

Advanced Features

4.13 IoT Integration & Usage-Based Insurance (FG-013)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-146	The system shall support IoT device integration for Usage-Based Insurance (UBI) via proprietary protocol	F	MQTT/CoAP protocol support, device authentication, encrypted communication
FR-147	The system shall collect and process IoT data: location, speed, temperature, health vitals based on insurance type	D	Real-time data ingestion, time-series database storage
FR-148	The system shall implement risk scoring based on IoT data patterns for dynamic premium adjustment	F	ML-based risk model, monthly recalculation, customer notification
FR-149	The system shall provide customer dashboard showing IoT insights and risk score with improvement tips	F	Visualization with charts, gamification elements, personalized recommendations
FR-150	The system shall support telematics integration for motor insurance with driving behavior analysis	D	Acceleration, braking, speed monitoring, trip history, safety score
FR-151	The system shall integrate with wearable devices for health insurance with fitness tracking	D	Steps, heart rate, sleep quality monitoring, wellness rewards program
FR-152	The system shall implement data privacy controls allowing customers to pause/resume IoT data collection	F	One-click toggle, data deletion option, privacy dashboard
FR-153	The system shall integrate with IoT devices: GPS trackers (vehicles), health wearables (fitness bands), smart home sensors (fire/water leak)	M3	MQTT/CoAP protocol support, device SDK documentation, API endpoints
FR-154	The system shall support IoT device registration, provisioning, and lifecycle management with certificate-based authentication	M3	X.509 certificates, device onboarding workflow, status tracking (active/inactive/suspe nded)
FR-155	The system shall process and store IoT telemetry data using MQTT broker with TimescaleDB for time-series storage	M3/ D	Handle 10,000 devices, 1 msg/min/device average, data retention policy (90 days hot, 2 years warm)

FR-156	The system shall generate real-time alerts based on IoT data thresholds: aggressive driving (>80km/h in city), health anomalies (heart rate), home incidents	M3/D	Rule engine for threshold monitoring, push notifications, SMS alerts, configurable rules
FR-157	The system shall support Usage-Based Insurance (UBI) pricing calculation based on IoT data: driving score (speed, braking, time-of-day), step count, heart rate variability	M3/D	Dynamic premium adjustment algorithm, monthly recalculation, transparent scoring dashboard
FR-158	The system shall provide IoT device management portal for partners to monitor connected devices, data streams, and device health	M3/D	Real-time device status, data visualization charts, anomaly detection, bulk operations
FR-159	The system shall support batch and real-time IoT data processing with configurable collection frequencies (1min to 1hour intervals)	M3/D	Stream processing (Kafka Streams), batch jobs, data quality checks, deduplication
FR-160	The system shall maintain IoT device inventory with status tracking (online/offline/maintenance/decommissioned) and metadata	M3/D	Device registry, heartbeat monitoring (5min timeout), auto-offline detection,

4.14 AI & Automation Features (FG-014)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-161	The system shall implement AI chatbot for customer assistance during product search, selection, purchase, and claims	F	Bengali NLP support, 80% query resolution, human handoff capability
FR-162	The system shall implement LLM multi-agent network for intelligent document processing and validation	F	OCR integration, field extraction accuracy >90%, fraud detection
FR-163	The system shall implement AI-powered fraud detection using pattern recognition and anomaly detection	D	ML model with continuous learning, risk scoring, false positive <10%
FR-164	The system shall support predictive analytics for risk assessment and premium optimization	F	Historical data analysis, model retraining, A/B testing capability
FR-165	The system shall implement voice-assisted workflow for Type 3 users (rural/low digital literacy)	F	Bengali speech recognition, step-by-step guidance, voice commands
FR-166	The system shall provide AI-based document verification with face matching and NID validation	M3	Liveness detection, face match confidence >95%, automated approval flow

AI Multi-Agent Architecture:

```
┌──────────────────────────────────────────────────────────────────┐
│                  AI ENGINE (Python + gRPC)                       │
├──────────────────────────────────────────────────────────────────┤
│  Agent 1: Document Processing                                    │
│  - OCR & Text Extraction                                         │
│  - NID/Document Validation                                       │
│  - Medical Report Analysis                                       │
├──────────────────────────────────────────────────────────────────┤
│  Agent 2: Customer Service                                       │
│  - Bengali Language Processing                                   │
│  - FAQ & Query Resolution                                        │
│  - Escalation Decision Making                                    │
├──────────────────────────────────────────────────────────────────┤
│  Agent 3: Risk Assessment                                        │
│  - Fraud Pattern Detection                                       │
│  - Behavioral Analysis                                           │
│  - Claim Risk Scoring                                            │
├──────────────────────────────────────────────────────────────────┤
│  Agent 4: Business Intelligence                                  │
│  - Predictive Analytics                                          │
│  - Market Trend Analysis                                         │
```

```
│   - Customer Segmentation                                    │
└──────────────────────────────────────────────────────────────┘
```

4.15 Voice-Assisted Features (FG-015)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-167	The system shall support Bengali speech-to-text (STT) with 90%+ accuracy for standard dialects (Dhaka, Chittagong, Sylhet)	M2	ASR model integration (Google/AWS/local), <2s latency, multi-dialect support
FR-168	The system shall provide voice-guided policy purchase workflow with step-by-step audio instructions in Bengali	M2	Complete policy purchase via voice, TTS integration, progress tracking
FR-169	The system shall support voice-based claims submission with automated transcription and field validation	M3	Voice recording up to 5min, transcription accuracy >85%, auto-populate claim form
FR-170	The system shall provide text-to-speech (TTS) for Bengali language with natural-sounding voice	M2	Natural prosody, <1s response time, caching for common phrases, offline fallback
FR-171	The system shall support voice navigation throughout mobile app for accessibility (elderly/visually impaired users)	D	Voice commands for all major functions, screen reader compatibility
FR-172	The system shall provide voice command taxonomy: "buy policy", "file claim", "check status", "pay premium", "call agent"	M2	Intent recognition with 85%+ accuracy, contextual understanding, error handling
FR-173	The system shall support seamless fallback to human agent when voice recognition confidence is below 80%	M3	Confidence scoring, automatic handoff with context transfer, queue management
FR-174	The system shall log and analyze voice interactions for continuous improvement with user consent	D	Voice data collection opt-in, anonymization, model retraining pipeline, performance metrics

4.16 Fraud Detection & Risk Controls (FG-016)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-175	The system shall flag claims submitted within 48hrs of policy purchase for manual review	M2	Auto-flagging with notification to Claims Officer, review queue
FR-176	The system shall detect same claim type >2 times in 12 months and flag for pattern analysis	M2	Historical claim analysis, risk scoring, enhanced verification
FR-177	The system shall flag claims where amount exactly matches policy limit (100% of coverage)	M2	Suspicious pattern detection, additional document requirements
FR-178	The system shall validate medical provider against approved network list and flag non-network claims	M2	Provider database, real-time validation, approval workflow
FR-179	The system shall implement device fingerprinting to detect multiple accounts from same device (>3 accounts)	M3	Browser/mobile device ID tracking, IP analysis, account linking
FR-180	The system shall provide fraud detection dashboard for Business Admin and Focal Person with drill-down capability	M2	Real-time alerts, risk score visualization, action buttons
FR-181	The system shall implement RACI for monitoring and incident escalation per defined roles	M1	Responsibility matrix enforced, escalation triggers,

Fraud Detection Rules:

Rule ID	Rule Description	Threshold	Action
FR-182	Rapid Policy-Claim: Policy purchase to claim submission	< 48 hours	Auto-flag + manual review
FR-183	Frequent Claims: Same claim type repetition	>2 times in 12 months	Flag + pattern analysis
FR-184	Amount Matching: Claim amount exactly matches coverage	100% of coverage	Flag + enhanced verification
FR-185	Network Violation: Medical provider not in approved list	Non-network provider	Flag + provider verification
FD-186	Geographic Anomaly: Claim location vs registered address	>100 km distance	Flag + location verification
FD-187	Device Fingerprinting: Multiple accounts from same device	>3 accounts	Flag + identity verification
FD-188	Behavioral Pattern: Unusual activity patterns	ML-based scoring	Risk scoring + monitoring

Admin & Reporting

4.17 Admin & Reporting (FG-017)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-189	The system shall provide role-based admin dashboards for: System Admin, Business Admin, Focal Person, Database Admin, Repository Admin	M1	Dynamic content based on role, real-time data updates
FR-190	The system shall enforce strict 2FA for all admin-level access with TOTP authentication	M1	Google Authenticator/Authy compatible, backup codes provided
FR-191	The system shall provide user management module: create, update, suspend, delete users with audit trail	M2	Full CRUD operations, role assignment, activity logs
FR-192	The system shall provide product management module: create, update, activate/deactivate insurance products	M1	Version control, effective date management, pricing configuration
FR-193	The system shall provide claims management dashboard with filtering: status, amount range, date, partner	M2	Advanced search, bulk actions, export functionality
FR-194	The system shall provide task management system with assignment to internal users and deadline tracking	D	Task creation, assignment, status updates, notification on overdue
FR-195	The system shall generate standard reports: daily sales, claims ratio, partner performance, policy counts, revenue	M2	M
FR-196	The system shall provide custom report builder with drag-drop interface for business users	D	Visual query builder, chart generation, saved report templates
FR-197	The system shall track KPIs aligned to business plan: policy acquisition rate, claim settlement ratio, customer retention	M3	M
FR-198	The system shall provide system health monitoring dashboard: server status, API response times, error rates	M2	Integration with Prometheus/Grafana, alert configuration

4.18 Analytics & Reporting (FG-018)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-199	The system shall track user behavior analytics: page views, feature usage, drop-off points, conversion funnel	D	Integration with analytics platform (Google Analytics/Mixpanel)
FR-200	The system shall provide predictive analytics for customer churn, claim likelihood, policy renewal probability	F	F
FR-201	The system shall generate customer segmentation reports: demographics, policy type, risk profile, lifetime value	D	Automated segmentation, export for marketing campaigns
FR-202	The system shall provide geographic analytics: policy distribution by district, claims heatmap, agent performance by region	D	Map visualization, district-level drill-down, comparative analysis
FR-203	The system shall provide geospatial risk visualization overlaying claims data on regional maps for heatmap analysis	D	Mapbox/Google Maps integration, district-level aggregation, color-coded risk zones
FR-204	The system shall provide pre-built dashboards: Executive, Operations, Compliance with drill-down	D	Interactive charts, export capability, scheduled email delivery
FR-205	The system shall track compliance metrics: AML flags, IDRA report status, audit logs access	D	Real-time compliance dashboard, alerts on violations

4.19 Audit & Logging (FG-019)

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-206	The system shall maintain immutable audit logs for critical actions: policy issue, claim approval, payment, dispute resolution	M1	PostgreSQL with append-only tables, tamper detection
FR-207	The system shall implement data retention policy with 20-year minimum for regulatory compliance	M2	Tiered storage (hot/warm/cold), automated archival, retrieval SLA
FR-208	The system shall track all logged-in user actions with IP address, device info, timestamp, action type	M3	Comprehensive logging, queryable audit trail, GDPR compliance
FR-209	The system shall allow partners to maintain additional logs as per MOU agreement with InsureTech	F	Partner-specific log tables, data isolation, access controls
FR-210	The system shall provide regulatory portal for IDRA/BFIU to access requested data as per law	M2	Secure portal, report generation, audit trail of data access
FR-211	The system shall implement log aggregation and analysis with alerting on suspicious patterns	M2	ELK stack/CloudWatch integration, anomaly detection, real-time alerts

Technical Architecture

4.20 System Interface Architecture (FG-020)

See Section 5.1 for Technical Protocols and Constraints.

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-212	The system shall implement High-Performance Internal API for gateway-microservices communication with low latency guarantees	M1	<100ms response time, circuit breaker pattern, retry logic
FR-213	The system shall implement Client-Optimized API for gateway-customer device communication with efficient data fetching	M1	<2s response time, query optimization, field-level authorization
FR-214	The system shall implement Standard Integration API for 3rd party partners with comprehensive documentation	D	<200ms response time, standardized docs, sandbox environment
FR-215	The system shall provide public Public Discovery API for product search and listing with rate limiting	M1	<1s response time, request limiting, caching enabled

FR-216	The system shall expose only Cloudflare proxy and NGINX entry node to public, blocking direct microservice access	M1	Firewall rules configured, internal IPs hidden, DDoS protection
FR-217	The system shall implement Real-Time Connection capability for instant updates (notifications, claims status)	D	Persistent connection management, automatic reconnection, heartbeat
FR-218	The system shall use Efficient Binary Protocol for IoT data extraction and data binding	F	Custom binary formatting, data compression, low latency
FR-219	The system shall consolidate, annotate and process data for AI agent training within regulatory limits	F	Data anonymization, consent management, audit trail
FR-220	The system shall generate statistics and predictions based on big data for partner insights	F	ML pipeline, data lake architecture, API for insights delivery
FR-221	The system shall implement Blockchain-based shared ledger for automated reinsurance settlements and smart contract execution	D	Immutable ledger, transparency audit trail
FR-222	The system shall implement AI-driven dynamic premium discounting based on real-time risk assessment and loyalty scoring	D	Risk model integration, real-time calculation, customer notification
FR-223	The system shall integrate with SMS Gateway for OTP and notifications	M1	Delivery rate >95%, delivery status tracking, cost optimization
FR-224	The system shall integrate with Email Service for transactional and marketing emails	M1	Template management, bounce handling, unsubscribe management
FR-225	The system shall provide Webhook System for real-time event notifications to external systems	M2	Event filtering, retry mechanism, authentication, payload signing

API Category Structure & Architecture:

Refer to Section 6.8 in 06_data_model.md for detailed API Category Specifications and System Interface Diagram.

Refer to Section 5.1 in 05_non_functional_requirements.md for specific protocol constraints (NFR-048 to NFR-050).

4.21 Integration (FG-021)

Details are consolidated in Section 8 (Integration Requirements). This section references those specifications for functional alignment.

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-226	The system shall provide API contract specification: All Category 3 APIs must provide OpenAPI 3.0 spec with request/response schemas, error codes, example payloads	M3	• OpenAPI spec complete • Error codes documented • Examples provided
FR-227	The system shall define insurer API payloads: Premium Calculation API, Policy Issuance API with standardized request/response formats	M1	• Payload formats defined • Validation rules clear • Sample payloads provided
FR-228	The system shall define payment gateway payloads: Initiate Payment, Webhook Callback with HMAC-SHA256 signature validation	M1	• Payment payloads defined • Signature validation implemented • Security tested
FR-229	The system shall implement retry logic: Failed API calls retry with exponential backoff: 1s, 2s, 4s, 8s, 16s (max 5 retries); Use circuit breaker pattern	M1	• Retry logic tested • Exponential backoff works • Circuit breaker functional
FR-230	The system shall implement idempotency: All payment and policy issuance APIs must accept Idempotency-Key header (UUID); Store keys for 24 hours; Return cached response for duplicates	M1	• Idempotency enforced • Key storage works • Duplicate handling correct
FR-231	The system shall implement callback security: Payment gateway webhooks must include HMAC-SHA256 signature in header; Validate signature; Reject unsigned/invalid callbacks; Log all attempts	M2	• Signature validation works • Invalid callbacks rejected • Logging comprehensive
FR-232	The system shall support EHR integration approach - Option A (Preferred): Use LabAid FHIR API with Patient resource matching by NID/phone; Query Encounter resources; Pre-authorization workflow	S	• FHIR API integrated • Patient matching accurate • Pre-auth workflow functional
FR-233	The system shall support EHR integration approach - Option B (Fallback): Use LabAid custom REST API with endpoints for patient admissions, pre-auth verification, bills; Secure with mutual TLS + API key	D	• Custom API integrated • mTLS configured • API key management

FR-234	The system shall handle EHR integration timeout: Set connection timeout 5s, read timeout 15s; If timeout, queue for manual verification; Notify hospital staff via SMS	D	• Timeout handling works • Manual queue functional • Notifications sent

4.22 Data Storage (FG-022)

Refer to Section 6 in 06_data_model.md for Data Model & Persistence details.

Refer to Section 5.1 in 05_non_functional_requirements.md for Database Technology Constraints.

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-235	The system shall use PostgreSQL V17 for structured data with JSON support and full-text search capability	M1	Primary database setup, performance optimization, localization
FR-236	The system shall implement read replicas for reporting and analytics workloads	M3	Read scaling, data consistency, performance monitoring
FR-237	The system shall implement Graph Database (Neo4j/Amazon Neptune) for visualizing complex fraud relationships and entity resolution	D	Graph schema defined, node relationship mapping, query performance <1s
FR-238	The system shall use Redis for session management and high-frequency real-time data	M3	Performance optimization, session management, cache strategies
FR-239	The system shall implement data partitioning for policies and claims tables by month	M3	Scalability, query performance, maintenance efficiency
FR-240	The system shall use S3-compatible Object Storage for document files with encryption at rest	M1	Secure document storage, lifecycle management, CDN integration
FR-241	The system shall store product catalog and metadata in Document-Oriented NoSQL Database	M3	Flexible schema, high availability, global distribution
FR-242	Upload data policy - Client-side compression: 5MB → 1-2MB (JPEG 80% quality, 1920x1080 max resolution), Chunked upload: 1MB chunks with resume capability (tus.io protocol), Presigned S3 URLs: Direct upload, 30-minute expiry	M1	check upload >5MB fails,<5MB passes
FR-243	Backup: Daily full, 6-hour incremental, continuous transaction logs	M1	Check new backup after 6hour
FR-244	The system shall store app native encrypted data in user device in SQLite	M2	Check sqlitefiles

FR-245	The system shall process tokenized data on Vector Database for AI embeddings	D	Similarity search latency check
FR-246	The system shall implement Columnar Database (ClickHouse/Druid) for high-performance real-time analytics and reporting	D	OLAP query performance <500ms, data compression, scalability

4.23 User Interface Requirements (FG-023)

4.23.1 Mobile Application (Android/iOS)

Customer Mobile App Requirements:

- Platform Support: Android 8.0+ (API 26), iOS 13.0+
- Language Support: Bengali (primary), English (secondary)
- Offline Capability: Policy documents, basic information viewable offline
- Accessibility: WCAG 2.1 AA compliance for visually impaired users
- Performance: App startup < 3 seconds, screen transitions < 1 second

FR ID	Requirement Description	Priority	Acceptance Criteria
FR-247	The system shall maintain consistent UI across Android and iOS using React Native	M1	Shared codebase >90%
FR-248	The system shall provide smart data widgets for mobile users	D	Customizable dashboard
FR-249	The system shall support desktop-first responsive design for portals	M1	1024px minimum width
FR-250	The system shall request minimum device permissions	M1	Camera, SMS read only
FR-251	The system shall support Bengali and English with toggle	M1	i18n framework implemented

Key Features:

- User registration and KYC verification with document upload
- Product browsing and comparison
- Policy purchase and premium payment
- Claims submission with photo/video upload
- Policy document management and sharing
- Push notifications and in-app messaging
- Voice-assisted navigation for elderly users

Agent Mobile App Requirements:

- All customer app features plus agent-specific functionality
- Lead management and customer onboarding assistance
- Commission tracking and earnings reports
- Offline policy issuance capability
- Customer support tools and knowledge base

4.23.2 Web Portals

Customer Web Portal:

- Responsive design (desktop, tablet, mobile)
- Single-page application (SPA) architecture using React
- Multi-language support with language switcher
- Dashboard with policy overview, premium due dates, claims status
- Document management with secure download links
- Payment history and receipt downloads

Partner Admin Portal:

- Agent management and performance monitoring
- Commission calculation and payment tracking
- Sales analytics and reporting dashboards
- Product configuration and pricing management
- Customer support tools and escalation workflows
- Bulk operations for agent onboarding

System Admin Portal:

- User and role management
- System configuration and feature toggles
- Monitoring dashboards and system health metrics
- Regulatory reporting and compliance tracking
- Audit log viewing and analysis
- Business intelligence and analytics tools

4.23.3 UI/UX Guidelines

Design Principles:

- Bangladesh-centric design with cultural sensitivity
- Mobile-first responsive design approach
- Accessibility compliance (WCAG 2.1 AA)
- Progressive Web App (PWA) capabilities
- Consistent color scheme and branding
- Bengali typography and text rendering optimization

Interaction Patterns:

- Intuitive navigation with minimal cognitive load
- Voice input support for Bengali language
- Gesture-based navigation on mobile devices
- Contextual help and guided tutorials
- Error prevention and graceful error handling
- Confirmation dialogs for critical actions

5. Non-Functional Requirements & Technical Constraints

5.1 Technology Constraints

NFR ID	Constraint Area	Requirement	Measurement	Priority
NFR-252	Database Technology	The system shall maintain relational data integrity using PostgreSQL V17 with JSONB support	ACID compliance tests	M1
NFR-253	Caching & Session	The system shall use Redis for distributed caching and session management	Cache hit ratio monitoring	M1
NFR-254	API Protocol	Microservices communication shall use gRPC with Protocol Buffers (Category 1)	Inter-service latency metrics	M1
NFR-255	Client API	Client-facing APIs shall use REST (OpenAPI 3.0) with JWT authentication	Schema validation, Token checks	M1
NFR-256	Public Integration	External integrations shall use RESTful APIs with OpenAPI 3.0 specifications (Category 3)	Swagger validator pass	D
NFR-257	Search Engine	Full-text search capabilities shall be implemented using PostgreSQL Full-Text Search or dedicated engine	Query performance <200ms	M1
NFR-258	Object Storage	Document and static asset storage shall use S3-compatible storage (AWS/DigitalOcean)	Upload/Download latency	M1
NFR-259	Message Broker	Asynchronous event processing shall be handled by Apache Kafka	Throughput monitoring	M1
NFR-260	Time-Series Data	IoT telemetry data shall be stored in TimescaleDB	Ingestion rate monitoring	M2
NFR-261	Vector Database	Vector embeddings for AI features shall be stored in Pgvector or Pinecone	Similarity search latency	D

NFR-262	Graph Database	Fraud visualization and relationship mapping shall use Neo4j or Amazon Neptune	Graph traversal depth/speed	D
NFR-263	Columnar Database	High-performance analytics shall use ClickHouse or Druid	Analytical query speed	D
NFR-264	Financial Ledger	Double-entry bookkeeping shall be enforced using TigerBeetle	Ledger reconciliation check	M3
NFR-265	Mobile Framework	Cross-platform mobile application shall be built using React Native	Code reuse >80%	M1
NFR-266	CDN & Security	Public entry points shall be secured via Cloudflare proxy	WAF block rate	M1

5.2 Performance Requirements

NFR ID	Requirement	Target	Measurement	Priority
NFR-267	API response time for policy operations	< 500ms (95th percentile)	Application performance monitoring	M1
NFR-268	Database query response time	< 100ms (average)	Database monitoring tools	M1
NFR-269	Mobile app startup time	< 3 seconds	App performance analytics	M1
NFR-270	Web portal page load time	< 2 seconds	Browser performance tools	M1
NFR-271	Payment processing time	< 10 seconds end-to-end	Payment gateway analytics	M1
NFR-272	Claim processing automation	80% straight-through processing	Business process monitoring	M2
NFR-273	Report generation time	< 30 seconds for standard reports	Reporting system metrics	M2
NFR-274	Search functionality response	< 200ms for basic searches	Search performance monitoring	M2

5.3 Scalability Requirements

NFR ID	Requirement	Target	Measurement	Priority
NFR-275	Concurrent user support	10,000 active users	Load testing and monitoring	M1
NFR-276	Transaction throughput	1,000 TPS (policies + claims)	Performance testing	M2
NFR-277	Database scalability	100 million policy records	Database performance testing	M2
NFR-278	Auto-scaling capability	Scale out/in based on load	Infrastructure monitoring	M2
NFR-279	Peak load handling	5x normal load during campaigns	Stress testing	M3
NFR-280	Storage scalability	10TB+ document storage	Cloud storage metrics	M3

5.4 Availability & Reliability

NFR ID	Requirement	Target	Measurement	Priority
NFR-281	System availability	99.5% uptime (M1), 99.9% (M2)	Infrastructure monitoring	M1
NFR-282	Recovery Time Objective (RTO)	4 hours maximum	Disaster recovery testing	M1
NFR-283	Recovery Point Objective (RPO)	1 hour maximum data loss	Backup and recovery testing	M1
NFR-284	Mean Time To Recovery (MTTR)	< 2 hours	Incident response metrics	M2
NFR-285	Service degradation handling	Graceful degradation during outages	Chaos engineering testing	M2
NFR-286	Data backup frequency	Real-time replication + daily backups	Backup monitoring	M1

5.5 Security Requirements

Refer to Section 7: Security & Compliance Requirements for detailed security controls.

5.6 Usability Requirements

NFR ID	Requirement	Target	Measurement	Priority
NFR-287	User satisfaction score	4.5+ stars on app stores	User feedback and ratings	M2
NFR-288	Task completion rate	95% for critical user journeys	User experience analytics	M1
NFR-289	Learning curve	New users complete first task < 5 minutes	User onboarding metrics	M2
NFR-290	Error recovery	Clear error messages with action guidance	Error tracking and analysis	M1
NFR-291	Accessibility compliance	WCAG 2.1 AA compliance	Accessibility testing tools	M2
NFR-292	Multi-language support	Bengali and English localization	Localization testing	M1

5.7 Maintainability & Operability

NFR ID	Requirement	Target	Measurement	Priority
NFR-293	Code coverage	80% unit test coverage	Automated testing reports	M2
NFR-294	Deployment frequency	Daily deployments capability	CI/CD pipeline metrics	M2
NFR-295	Mean Time To Deploy	< 30 minutes for hotfixes	Deployment automation metrics	M2
NFR-296	Monitoring coverage	100% critical path monitoring	Observability platform	M1
NFR-297	Log aggregation	Centralized logging for all services	Logging platform metrics	M1
NFR-298	Documentation currency	API documentation auto-generated	Documentation automation	M2

5.8 Compliance Requirements

Refer to Section 7: Security & Compliance Requirements for detailed IDRA and BFIU compliance frameworks.

6. Data Model & Persistence

6.1 Proto Schema Organization

All data models are defined using Protocol Buffers (proto3) and organized by domain with a consistent structure:

```
proto/insuretech/
├── authn/                          Authentication Domain
│   ├── entity/v1/                  Data entities
│   │   ├── user.proto
│   │   └── session.proto
│   ├── events/v1/                  Domain events
│   │   └── auth_events.proto
│   └── services/v1/                gRPC services
│       └── auth_service.proto
│
├── authz/                          Authorization Domain
│   ├── entity/v1/
│   ├── events/v1/
│   └── services/v1/
│
├── policy/                         Policy Management Domain
│   ├── entity/v1/
│   │   └── policy.proto
│   ├── events/v1/
│   └── services/v1/
│
├── claims/                         Claims Processing Domain
│   ├── entity/v1/
│   │   └── claim.proto
│   ├── events/v1/
│   └── services/v1/
│
├── payment/                        Payment Processing Domain
│   ├── entity/v1/
│   │   └── payment.proto
│   ├── events/v1/
│   └── services/v1/
│
├── partner/                        Partner Management Domain
│   ├── entity/v1/
│   │   └── partner.proto
│   ├── events/v1/
│   └── services/v1/
│
├── products/                       Product Catalog Domain
│   ├── entity/v1/
│   ├── events/v1/
│   └── services/v1/
│
├── notification/                   Notification Domain
│   ├── entity/v1/
```

```
│    ├── events/v1/
│    └── services/v1/
│
├── ai/                              AI Engine Domain
│    ├── entity/v1/
│    ├── events/v1/
│    └── services/v1/
│
├── analytics/                        Analytics & BI Domain
│    ├── entity/v1/
│    ├── events/v1/
│    └── services/v1/
│
└── iot/                             IoT Integration Domain
     ├── entity/v1/
     ├── events/v1/
     └── services/v1/
```

See Appendix A for complete proto definitions with code examples.

6.2 Data Architecture Overview

The LabAid InsureTech Platform uses a hybrid data architecture combining Protocol Buffers for service contracts with optimized database schemas for persistence:

Data Storage Strategy:

- PostgreSQL 17+: Primary transactional data (policies, claims, users, KYC)
- TimescaleDB: Time-series data (IoT telemetry, audit logs, analytics)
- TigerBeetle: Financial transactions with double-entry bookkeeping
- DynamoDB: Product catalog, configuration, session data
- Redis 7.0+: Caching, session management, real-time data
- AWS S3: Document storage (policy certificates, claims documents, images)
- Apache Kafka: Event streaming and audit logs
- Pgvector: Vector embeddings for AI/ML operations

6.3 Domain Models

6.3.1 Core Entities

Authentication Domain:

- User - Registered users with mobile/email
- Session - Active user sessions with JWT tokens
- OTP - One-time passwords for verification

Policy Domain:

- Policy - Insurance policies with coverage details
- Applicant - Policyholder information
- Nominee - Beneficiaries with share percentages

- Rider - Additional coverage options

Claims Domain:

- Claim - Claim submissions with status tracking
- ClaimDocument - Supporting documents (bills, reports)
- ClaimApproval - Multi-level approval workflow
- FraudCheck - Fraud detection results

Payment Domain:

- Payment - Financial transactions
- Transaction - Double-entry accounting records
- Refund - Refund processing

Partner Domain:

- Partner - Business partners (hospitals, MFS, e-commerce)
- Agent - Sales representatives
- Commission - Commission structure and calculations

6.4 Proto-First Data Model Strategy

6.4.1 Why Proto-First?

Single Source of Truth:

The LabAid InsureTech Platform adopts a Proto-First approach where Protocol Buffer definitions serve as the canonical data model across all layers:

```
Proto Definitions (Source of Truth)
    ├── Code Generation → Go/C#/Python/Node.js structs
    ├── Database Schema → PostgreSQL/TimescaleDB tables
    ├── API Contracts → gRPC/REST endpoints
    ├── Event Schemas → Kafka message formats
    └── Documentation → Auto-generated API docs
```

Key Benefits:

- ✅ Type Safety: Compile-time validation across all services
- ✅ Consistency: Same data structure in app, database, and APIs
- ✅ Versioning: Built-in support for backward/forward compatibility
- ✅ Multi-Language: Generate code for Go, C#, Python, Node.js from single source
- ✅ Performance: Efficient binary serialization with Protocol Buffers
- ✅ Documentation: Self-documenting with comments in proto files

6.4.2 Schema Generation Workflow

Step 1: Define Proto Schemas

```
// proto/insuretech/policy/entity/v1/policy.proto
message Policy {
  string policy_id = 1;                    // UUID
  string policy_number = 2;                // LBT-YYYY-XXXX-NNNNNN
  string customer_id = 3;
  PolicyStatus status = 4;
  double premium_amount = 5;
  google.protobuf.Timestamp created_at = 6;
}
```

Step 2: Generate Database Schema

```
# Using buf or protoc-gen-sql
buf generate

# Outputs: migrations/001_initial_schema.sql
CREATE TABLE policies (
    policy_id UUID PRIMARY KEY,
    policy_number VARCHAR(50) UNIQUE NOT NULL,
    customer_id UUID NOT NULL,
    status VARCHAR(50) NOT NULL,
    premium_amount DECIMAL(12,2) NOT NULL,
    created_at TIMESTAMP NOT NULL
);
```

Step 3: Manual Optimization (Enhancement Layer)

```
-- migrations/002_add_indexes.sql
CREATE INDEX idx_policies_customer_id ON policies(customer_id);
CREATE INDEX idx_policies_status ON policies(status);
CREATE INDEX idx_policies_created_at ON policies(created_at DESC);

-- Add foreign keys
ALTER TABLE policies ADD CONSTRAINT fk_customer
    FOREIGN KEY (customer_id) REFERENCES users(user_id);

-- Add constraints
ALTER TABLE policies ADD CONSTRAINT chk_premium_positive
    CHECK (premium_amount > 0);
```

Step 4: Generate Application Code

```
# Go
protoc --go_out=. --go-grpc_out=. proto/**/*.proto

# C#
protoc --csharp_out=. --grpc_out=. proto/**/*.proto

# Python
python -m grpc_tools.protoc -I. --python_out=. --grpc_python_out=. proto/**/*.proto
```

6.4.3 Database Strategy by Type

PostgreSQL (Primary Transactional Database)

Generated Tables:

```
From proto/insuretech/authn/entity/v1/*.proto:
  ├── users               (User proto → users table)
  ├── user_profiles       (UserProfile proto)
  ├── sessions            (Session proto)
  └── otps                (OTP proto)

From proto/insuretech/policy/entity/v1/*.proto:
  ├── policies            (Policy proto)
  ├── policy_nominees     (Nominee proto)
  └── policy_riders       (Rider proto)

From proto/insuretech/claims/entity/v1/*.proto:
  ├── claims              (Claim proto)
  ├── claim_documents     (ClaimDocument proto)
  ├── claim_approvals     (ClaimApproval proto)
  └── fraud_checks        (FraudCheckResult proto)

From proto/insuretech/payment/entity/v1/*.proto:
  └── payments            (Payment proto)

From proto/insuretech/partner/entity/v1/*.proto:
  ├── partners            (Partner proto)
  └── agents              (Agent proto)
```

Enhancement Strategy:

- Indexes: Add for frequently queried columns (customer_id, status, dates)
- Foreign Keys: Enforce referential integrity
- Constraints: Business rules (amount > 0, dates logical)
- Triggers: Audit logging, automatic timestamp updates
- Partitioning: For large tables (policies by year, claims by month)

TimescaleDB (Time-Series Database)

Generated Hypertables:

```
From proto/insuretech/iot/entity/v1/device.proto:
  └── telemetry          (Telemetry proto → hypertable on timestamp)

From proto/insuretech/authn/events/v1/*.proto:
  └── audit_logs         (Event protos → hypertable)

From proto/insuretech/analytics/entity/v1/*.proto:
  └── metrics            (Metric proto → hypertable)
```

Enhancement Strategy:

```
-- Create hypertable
SELECT create_hypertable('telemetry', 'timestamp');
```

```
-- Add continuous aggregates for dashboards
CREATE MATERIALIZED VIEW telemetry_hourly
WITH (timescaledb.continuous) AS
SELECT time_bucket('1 hour', timestamp) AS hour,
       device_id,
       AVG(metrics->>'speed') as avg_speed,
       COUNT(*) as data_points
FROM telemetry
GROUP BY hour, device_id;

-- Set retention policy (90 days hot, archive rest)
SELECT add_retention_policy('telemetry', INTERVAL '90 days');
```

DynamoDB (NoSQL Document Store)

Generated Collections:

```
From proto/insuretech/products/entity/v1/product.proto:
  └── products_catalog   (Product proto → DynamoDB items)

From proto/insuretech/authn/entity/v1/session.proto:
  └── active_sessions    (Session proto → TTL-enabled items)
```

Key Design:

- Primary Key: entity_id (from proto)
- Sort Key: timestamp or type (from proto fields)
- TTL: For session data (expires_at from proto)
- Global Secondary Indexes: Based on query patterns

TigerBeetle (Financial Ledger)

Generated Accounts:

```
From proto/insuretech/payment/entity/v1/payment.proto:
  Account types mapped from PaymentType enum:
  ├── Premium Collection Accounts
  ├── Claims Settlement Accounts
  ├── Commission Payment Accounts
  └── Refund Accounts
```

Double-Entry Example:

```
Premium Payment (BDT 1,500):
  Debit:  Customer Account        -1,500 BDT
  Credit: Premium Collection      +1,500 BDT
```

6.4.4 Migration Strategy

Phase 1: Initial Schema Generation

```
# Generate from all entity protos
protoc-gen-sql \
  --out=migrations/001_initial_schema.sql \
  proto/insuretech/*/entity/v1/*.proto
```

```
# Apply to database
psql -d insuretech_dev -f migrations/001_initial_schema.sql
```

Phase 2: Add Enhancements

```
-- migrations/002_add_indexes.sql
CREATE INDEX CONCURRENTLY idx_policies_customer_status
    ON policies(customer_id, status);

-- migrations/003_add_foreign_keys.sql
ALTER TABLE policies ADD CONSTRAINT fk_customer ...;
ALTER TABLE claims ADD CONSTRAINT fk_policy ...;

-- migrations/004_add_partitioning.sql
CREATE TABLE policies_2025 PARTITION OF policies
    FOR VALUES FROM ('2025-01-01') TO ('2026-01-01');
```

Phase 3: Data Migration

```
-- migrations/005_migrate_legacy_data.sql
INSERT INTO users (user_id, mobile_number, ...)
SELECT uuid_generate_v4(), phone, ...
FROM legacy_customers;
```

Phase 4: Performance Optimization

```
-- migrations/006_optimize_queries.sql
CREATE MATERIALIZED VIEW policy_summary AS
SELECT customer_id, COUNT(*) as policy_count, SUM(premium_amount) as total_premium
FROM policies WHERE status = 'ACTIVE'
GROUP BY customer_id;

-- Refresh strategy
REFRESH MATERIALIZED VIEW CONCURRENTLY policy_summary;
```

6.4.5 Schema Versioning Strategy

Proto Evolution:

```
// v1 - Initial version
message Policy {
  string policy_id = 1;
  double premium_amount = 2;
}

// v2 - Add new field (backward compatible)
message Policy {
  string policy_id = 1;
  double premium_amount = 2;
  string partner_id = 3;        // New field - optional by default
}

// v3 - Deprecate field (forward compatible)
message Policy {
  string policy_id = 1;
  double premium_amount = 2;
```

```
  string partner_id = 3;
  double old_field = 4 [deprecated = true];  // Mark as deprecated
}
```

Database Migration for Proto Changes:

```
-- When adding field to proto
ALTER TABLE policies ADD COLUMN partner_id UUID;

-- When deprecating field
-- Keep column for backward compatibility, mark in comments
COMMENT ON COLUMN policies.old_field IS 'DEPRECATED: Use new_field instead';

-- After grace period, drop column
ALTER TABLE policies DROP COLUMN old_field;
```

6.4.6 Data Consistency Patterns

Strong Consistency (PostgreSQL)

```
Policy Creation:
  1. Begin Transaction
  2. Insert into policies
  3. Insert into policy_nominees
  4. Insert into policy_riders
  5. Commit (all or nothing)
```

Eventual Consistency (Event-Driven)

```
Policy Issued Event → Kafka:
  ├→ Notification Service (send SMS)
  ├→ Analytics Service (update metrics)
  ├→ Partner Service (calculate commission)
  └→ Document Service (generate PDF)

Each service processes independently with retries
```

CQRS Pattern

```
Command (Write):
  Proto → Service Logic → PostgreSQL (write) → Kafka Event

Query (Read):
  Proto → Read Model (materialized view) → Fast response
```

7.4.7 Backup and Recovery

PostgreSQL Backup:

```
# Daily full backup
pg_dump insuretech_prod > backup_$(date +%Y%m%d).sql

# Point-in-time recovery (WAL archiving)
archive_command = 'cp %p /archive/%f'
```

Proto Schema Backup:

```
# Proto files are version controlled in Git
git tag v3.7-schemas
git push origin v3.7-schemas

# Can regenerate schemas from any tagged version
git checkout v3.7-schemas
buf generate
```

6.5 Data Migration Strategy

Proto-to-Database Mapping:

- Proto definitions serve as canonical data models
- Database schemas generated from proto files
- Migrations managed via version-controlled SQL scripts
- Backward compatibility maintained through proto versioning

Migration Phases:

- Phase 1: Core entities (User, Policy, Claim, Payment)
- Phase 2: Extended entities (Partner, Agent, Product)
- Phase 3: Advanced features (IoT, AI, Analytics)

6.6 CQRS Implementation

Command Side (Write):

- Commands update primary PostgreSQL database
- Events published to Kafka
- Strong consistency guarantees

Query Side (Read):

- Materialized views for complex queries
- Read replicas for reporting
- Eventual consistency acceptable
- Cached frequently accessed data in Redis

Example Flow:

```
CreatePolicy Command → PostgreSQL INSERT → Kafka PolicyCreated Event
                     ↓
              Read Model Update (async)
                     ↓
        Policy Query → Redis Cache → Read Replica
```

6.7 Data Retention & Archival

Data Type	Hot Storage	Warm Storage	Cold Storage	Retention
Active Policies	PostgreSQL	-	-	Policy lifetime
Expired Policies	PostgreSQL (1 year)	S3 (5 years)	Glacier (20 years)	20 years
Claims Data	PostgreSQL	S3 after settlement	Glacier (20 years)	20 years
Audit Logs	TimescaleDB (90 days)	S3 (1 year)	Glacier (7 years)	7 years
IoT Telemetry	TimescaleDB (90 days)	S3 (1 year)	Deleted	1 year
User Sessions	Redis (7 days)	-	-	7 days

For complete proto definitions with code examples, see Appendix A.

6.8 System Interface Architecture

6.8.1 API Category Specifications

API Category	Protocol	Use Case	Security Layer	Performance Target
Category 1	Protocol Buffer + gRPC	Gateway ↔ Microservices	System Admin Middle Layer	< 100ms
Category 2	GraphQL + JWT	Gateway ↔ Customer Device	JWT + OAuth v2	< 2 seconds
Category 3	RESTful + JSON (OpenAPI)	3rd Party Integration	Server-side Auth	< 200ms
Public API	RESTful + JSON (OpenAPI)	Product Search/List	Public Access	< 1 second

6.8.2 System Interface Diagram

\\\

```
┌──────────────
```

```
│3rd    │ │ Microservices    │ │  (Kafka     │
│Party  │ │ Communication    │ │  Orchestrated)│
└──────────┘ └──────────────────────────┘ └──────────────────────────┘
```

\\\

7. Security & Compliance Requirements

& Compliance Requirements

The LabAid InsureTech Platform implements a Zero Trust Security Model with defense-in-depth strategies:

Core Security Principles:

- Never Trust, Always Verify: All users and devices authenticated and authorized
- Least Privilege Access: Minimum required permissions for each role
- Assume Breach: Monitor and respond as if compromise has occurred
- Encrypt Everything: Data protection at all layers and states
- Continuous Monitoring: Real-time threat detection and response

7.1 Security Infrastructure & Key Management

ID	Requirement Description	Priority
SEC-001	The system shall use separate secret vault - AWS KMS/Azure Key Vault/HashiCorp, 90-day key rotation	M1
SEC-002	The system shall use Data Masking: NID (last 3 digits), phone (mask middle), email (mask username)	M2
SEC-003	The system shall follow PCI-DSS compliance for card flows - Approach: Hosted payment page (redirect model) - DO NOT store card data, Level: SAQ-A (simplest, for redirecting merchants), Requirements: Annual SAQ, quarterly ASV scans, TLS 1.3, Tokenization: Store only gateway tokens for recurring payments	M2
SEC-004	The system shall have AML/CFT detection hooks - Transaction Monitoring: 20+ automated rules for AML detection including Rapid purchases (>3 policies in 7 days), High-value premiums (>BDT 5 lakh), Frequent cancellations, Mismatched nominees, Geographic/payment anomalies	D
SEC-005	The system shall have IDRA reporting capabilities following IDRA data format - Monthly Reports: Premium Collection (Form IC-1), Claims Intimation (Form IC-2), Quarterly Reports: Claims Settlement (IC-3), Financial Performance (IC-4), Annual Reports: FCR (Financial Condition Report), CARAMELS Framework Returns, Event-Based: Significant incidents (48hrs), fraud cases (7 days), Platform: Report generator with IDRA Excel templates, audit trail, 20-year archive	D
SEC-006	The system shall have regular penetration testing - Penetration Testing: Pre-launch + annually (SISA InfoSec or international firm)	D
SEC-007	The system shall have regular security audits from various security auditors and regulatory bodies and maintain compliance	D
SEC-008	DAST: OWASP ZAP/Burp Suite (weekly on staging)	D
SEC-009	SAST: SonarQube/Checkmarx (every commit, block critical vulnerabilities)	D
SEC-010	Virus scanning: ClamAV on uploaded files	M
SEC-011	The system shall implement API rate limiting per user/IP: 1000 requests/hour for authenticated users, 100 requests/hour for anonymous	M2
SEC-012	The system shall maintain separate encryption keys for different data types with hierarchical key management	M2
SEC-013	The system shall implement real-time security incident response with automated threat isolation	M2
SEC-014	The system shall perform continuous vulnerability assessment with automated patching for critical vulnerabilities	D
SEC-015	The system shall implement zero-trust network architecture with microsegmentation	D

7.2 Enhanced IDRA Compliance (MD FEEDBACK)

ID	Requirement Description	Priority
SEC-016	IDRA Monthly Reports: Generate Form IC-1 (Premium Collection) by 10th of each month with breakdown by product line, geographic region, partner channel in Excel format per IDRA template v2024	M2
SEC-017	IDRA Monthly Reports: Generate Form IC-2 (Claims Intimation) by 10th of each month listing all new claims with policy number, claim amount, claim type, date of intimation	M2
SEC-018	IDRA Quarterly Reports: Generate Form IC-3 (Claims Settlement) within 15 days of quarter-end showing settlement ratio, average TAT, pending >30 days breakdown	M2
SEC-019	IDRA Quarterly Reports: Generate Form IC-4 (Financial Performance) within 20 days of quarter-end with premium earned, claims paid, commission paid, net profit/loss	M3
SEC-020	IDRA Annual FCR: Generate Financial Condition Report (FCR) within 90 days of year-end including full CARAMELS framework assessment with external auditor sign-off	M3
SEC-021	IDRA Event-Based Reporting: Report significant incidents (fraud >BDT 1L, data breach, system outage >4hrs) within 48 hours via IDRA portal	M3

7.3 Enhanced AML/CFT Compliance (MD FEEDBACK)

ID	Requirement Description	Priority
SEC-022	AML/CFT Concrete Triggers: Flag transactions matching: (1) >3 policies in 7 days, (2) Premium >BDT 5L without income proof, (3) Nominee mismatch with no relationship doc, (4) Payment from third-party account, (5) Frequent cancellations >2 in 30 days, (6) Geographic anomaly (policy in Dhaka, payment from remote district), (7) Multiple failed KYC attempts >3, (8) PEP match in screening	M3
SEC-023	SAR Workflow: (1) System auto-flags suspicious transaction → (2) Compliance Officer reviews within 24hrs → (3) If confirmed suspicious, escalate to Business Admin+Focal Person → (4) Prepare SAR with evidence → (5) Submit to BFIU within 3 business days → (6) Mark account for enhanced monitoring → (7) Do NOT notify customer (tipping off prohibited)	M3
SEC-024	Data Deletion Exceptions: Customer data deletion requests processed within 30 days EXCEPT: (a) Active policy holders (deletion after policy expiry+7yrs), (b) Ongoing claims (deletion after settlement+7yrs), (c) Under SAR investigation (deletion prohibited until case closed), (d) Regulatory hold (deletion requires IDRA/BFIU approval)	M3
SEC-025	Right to Erasure Workflow: Customer submits deletion request → System validates exceptions → If eligible, anonymize PII while retaining transaction records → Generate deletion certificate → Notify customer within 30 days	D

7.4 Data Protection & Encryption Standards

Data Classification	Encryption Standard	Key Management	Access Control
Personally Identifiable Information (PII)	AES-256	AWS KMS with 90-day rotation	Role-based with audit logging
Financial Transaction Data	AES-256 + Additional Hashing	TigerBeetle built-in encryption	Restricted access with MFA
KYC Documents	AES-256 with client-side encryption	End-to-end encryption	Compliance officer access only
Medical Records	AES-256 with additional anonymization	Healthcare-specific key management	Medical staff + consent-based
Audit Logs	AES-256 with immutable storage	Centralized key management	Read-only access for auditors

7.5 Authentication & Authorization

Multi-Factor Authentication (MFA):

- SMS OTP for mobile number verification
- Email verification for account recovery
- Biometric authentication on supported mobile devices
- Hardware tokens for admin users

Role-Based Access Control (RBAC):

```
Roles Hierarchy:
├── System Admin
│   ├── Full system access
│   ├── User management
│   └── Security configuration
├── Business Admin
│   ├── Business operations
│   ├── Reporting access
│   └── Policy management
├── Partner Admin
│   ├── Agent management
│   ├── Commission tracking
│   └── Customer support
├── Agent
│   ├── Customer onboarding
│   ├── Policy sales
│   └── Basic support
└── Customer
    ├── Policy management
    ├── Claims submission
    └── Profile updates
```

Session Management:

- JWT tokens with 15-minute expiry
- Refresh token rotation
- Session invalidation on suspicious activity
- Device fingerprinting for fraud detection

7.6 IDRA Compliance Requirements

IDRA ID	Requirement Description	Reporting Frequency	Priority	Owner
IDRA-001	Digital insurance product approval and registration	One-time + updates	M3	Compliance Team
IDRA-002	Customer data protection and privacy compliance	Quarterly review	M3	Security Team
IDRA-003	Policy issuance and documentation standards	Real-time compliance	M3	Insurance Engine
IDRA-004	Claims processing and settlement reporting	Monthly	M3	Claims Team
IDRA-005	Financial solvency and capital adequacy reporting	Quarterly	M3	Finance Team
IDRA-006	Agent licensing and training compliance	Ongoing	M3	Partner Management
IDRA-007	Marketing and sales practice compliance	Quarterly	M3	Marketing Team
IDRA-008	Actuarial and risk management reporting	Annual	D	Risk Management
IDRA-009	Audit trail and record keeping requirements	Ongoing	M3	Audit System
IDRA-010	Regulatory change management and updates	As required	M3	Compliance Team

7.7 BFIU Anti-Money Laundering (AML) Compliance

BFIU ID	Requirement Description	Threshold	Priority	Implementation
BFIU-001	Customer due diligence (CDD) for all policyholders	All customers	M3	KYC verification system
BFIU-002	Enhanced due diligence (EDD) for high-value policies	>50,000 BDT sum assured	M3	Risk scoring system
BFIU-003	Suspicious transaction monitoring and reporting	Real-time analysis	M3	AI fraud detection
BFIU-004	Cash transaction reporting	>10,000 BDT	M3	Payment monitoring
BFIU-005	Wire transfer monitoring	>100,000 BDT	M3	Transaction screening
BFIU-006	Politically exposed person (PEP) screening	All customers	M3	PEP database integration
BFIU-007	Sanctions list screening	All parties	M3	Sanctions database
BFIU-008	Record retention for AML purposes	5 years minimum	M3	Data retention policies
BFIU-009	AML training for employees and agents	Annual certification	M2	Training management
BFIU-010	AML audit and compliance reporting	Quarterly	M3	Compliance dashboard

7.7.1 Customer Risk Scoring Matrix

Risk Factors:

- Transaction Frequency: >3 claims in 6 months = +20 points
- Transaction Amount: Single transaction >50K BDT = +15 points
- Geographic Anomaly: Claim location far from registered address = +10 points
- KYC Completeness: Missing NID verification = +25 points
- Device Fingerprinting: Multiple accounts from same device = +15 points
- Behavioral Anomaly: Unusual activity patterns = +10 points

Risk Categories:

- Low Risk: 0-30 points → Annual review
- Medium Risk: 31-60 points → Semi-annual review
- High Risk: >60 points → Quarterly review + Enhanced monitoring

7.7.2 Automated AML Monitoring Rules

Transaction Monitoring Rules (20+ Rules):

Rule ID	Rule Description	Threshold	Action
TM-001	Structuring: Multiple transactions just below reporting threshold	3+ transactions of 9K-10K BDT in 7 days	Flag for review
TM-002	Rapid Movement: Quick policy purchase and claim	Claim within 7 days of purchase	Flag + manual review
TM-003	Geographic Anomaly: Claim far from registered address	>100 km distance	Flag + location verification
TM-004	Frequency Anomaly: Frequent claims	>3 claims in 6 months	Flag + pattern analysis
TM-005	Amount Anomaly: Claim amount near coverage limit	>90% of coverage	Flag + document verification
TM-006	Device Anomaly: Multiple accounts from same device	>3 accounts	Flag + fraud investigation
TM-007	Payment Method Switch: Frequent payment method changes	>2 changes in 30 days	Flag + verification
TM-008	Rapid Purchases: Multiple policies in short timeframe	>3 policies in 7 days	Flag + EDD
TM-009	High-Value Premiums: Single premium exceeds threshold	>BDT 5 lakh	Enhanced due diligence
TM-010	Frequent Cancellations: Policy cancellation patterns	>2 cancellations in 3 months	Flag + investigation
TM-011	Mismatched Nominees: Nominee not family member	Non-relative nominee	Flag + verification
TM-012	Payment Source Anomaly: Different payers for same policy	>2 different payers	Flag + source verification
TM-013	Geographic Risk: High-risk geographic location	Blacklisted areas	Enhanced monitoring
TM-014	Age Anomaly: Unusual age for product type	Outside typical range	Flag + verification
TM-015	Occupation Risk: High-risk occupation categories	PEP, cash-intensive business	Enhanced due diligence
TM-016	Document Inconsistency: Mismatched KYC documents	OCR verification failure	Flag + manual review
TM-017	Refund Requests: Frequent refund requests	>2 refunds in 6 months	Flag + pattern analysis
TM-018	Beneficiary Changes: Multiple beneficiary modifications	>2 changes in 12 months	Flag + verification
TM-019	Third-Party Payments: Non-policyholder making payments	Different payer than insured	Flag + source verification
TM-020	Dormant Activation: Long-dormant account suddenly active	No activity >6 months then sudden purchase	Flag + identity verification

Customer Risk Scoring:

Risk Factor	Points	Description
Transaction Frequency	+20	>3 claims in 6 months
Transaction Amount	+15	Single transaction >50K BDT
Geographic Anomaly	+10	Claim location far from registered address
KYC Completeness	+25	Missing NID verification
Device Fingerprinting	+15	Multiple accounts from same device
Behavioral Anomaly	+10	Unusual activity patterns

Risk Categories:

- Low Risk: 0-30 points → Annual review
- Medium Risk: 31-60 points → Semi-annual review
- High Risk: >60 points → Quarterly review + Enhanced monitoring

STR/SAR Filing Workflow:

- Detection: Automated rule triggers or manual reporting by staff
- Investigation: Compliance Officer reviews flagged activity within 24 hours
- Decision: Determine if suspicious (consult with Business Admin if needed)
- Filing: Submit STR/SAR to BFIU portal within 7 days
- Action: Freeze account if necessary, notify authorities
- Documentation: Maintain records for 7 years
- No Tipping Off: Customer must not be notified per law

Rule ID	Rule Description	Threshold	Action
TM-021	Structuring: Multiple transactions just below reporting threshold	3+ transactions of 9K-10K BDT in 7 days	Flag for review
TM-022	Rapid Movement: Quick policy purchase and claim	Claim within 7 days of purchase	Flag + manual review
TM-023	Geographic Anomaly: Claim far from registered address	>100 km distance	Flag + location verification
TM-024	Frequency Anomaly: Frequent claims	>3 claims in 6 months	Flag + pattern analysis
TM-025	Amount Anomaly: Claim amount near coverage limit	>90% of coverage	Flag + document verification
TM-026	Device Anomaly: Multiple accounts from same device	>3 accounts	Flag + fraud investigation
TM-027	Payment Method Switch: Frequent payment method changes	>2 changes in 30 days	Flag + verification
TM-028	Time Anomaly: Transactions outside normal hours	11 PM - 6 AM transactions	Flag + review
TM-029	Velocity Check: High transaction volume	>10 transactions per day	Flag + velocity analysis
TM-030	Round Amount: Suspicious round number patterns	Multiple round amounts (10K, 20K, 50K)	Flag + pattern review

7.7.3 STR/SAR Filing Workflow

- Detection: Automated rule triggers or manual reporting by staff
- Investigation: Compliance Officer reviews flagged activity within 24 hours
- Decision: Determine if suspicious (consult with Business Admin if needed)
- Filing: Submit STR/SAR to BFIU portal within 7 days
- Action: Freeze account if necessary, notify authorities
- Documentation: Maintain records for 7 years
- No Tipping Off: Customer must not be notified per law

7.8. AML/CFT Compliance Requirements

7.8.1 Customer Due Diligence (CDD) Framework

Mandatory CDD Requirements for Bangladesh:

Requirement	Implementation	Compliance Standard
Identity Verification	NID/Passport verification via approved eKYC	BFIU Guidelines
Address Verification	Utility bill or bank statement	MLPA Requirements
Photo Identification	Selfie with liveness detection	Enhanced CDD
Source of Funds	Income declaration for high-value policies	Risk-based approach
PEP Screening	Automated screening against watchlists	FATF Recommendations

7.8.2 Risk-Based Customer Categorization

Risk Level	Criteria	CDD Requirements	Monitoring Frequency
Low Risk	Standard customers, low premium policies	Standard CDD	Annual review
Medium Risk	Higher premiums, multiple policies	Enhanced documentation	Quarterly review
High Risk	PEPs, large premiums, suspicious patterns	Enhanced Due Diligence (EDD)	Monthly monitoring
Prohibited	Sanctioned individuals, blocked entities	Transaction rejection	Real-time blocking

7.8.3 Automated AML Monitoring Rules

Monitoring Rule	Threshold	Alert Level	Action Required
Rapid Policy Purchases	>3 policies in 7 days	High	Enhanced verification
High-Value Premiums	>BDT 5 lakh	High	Management approval
Frequent Cancellations	>2 cancellations in 30 days	Medium	Pattern analysis
Mismatched Nominees	Different family names without relationship proof	Medium	Additional documentation
Geographic Anomalies	Transaction from unusual location	Low	Location verification
Payment Method Inconsistency	Different mobile numbers vs NID	Medium	Customer verification

7.8.4 Record Keeping & Audit Trail

Document Type	Retention Period	Storage Requirements	Access Controls
CDD Documentation	5+ years after relationship end	Encrypted PostgreSQL + S3	Compliance team only
Transaction Records	7+ years	TigerBeetle + Archive	Audit and compliance
STR Documentation	10+ years	Secured offline storage	Business Admin + Focal Person
Training Records	5+ years	HR system integration	HR and compliance
System Audit Logs	20+ years	Immutable PostgreSQL logging	System administrators

7.9 Data Protection & Privacy

Privacy by Design Implementation:

- Data minimization in collection and processing
- Purpose limitation for data usage
- Storage limitation with automated purging
- Accuracy maintenance with user control
- Security safeguards at all layers
- Transparency through privacy notices
- User control over personal data

Data Subject Rights (GDPR-Style):

- Right to access personal data
- Right to rectification of inaccurate data
- Right to erasure ("right to be forgotten")
- Right to restrict processing
- Right to data portability
- Right to object to processing
- Rights related to automated decision making

7.10 Cybersecurity Measures

Threat Protection:

```
Defense Layers:
├── Network Security
│   ├── WAF (Web Application Firewall)
│   ├── DDoS protection
│   └── Network segmentation
├── Application Security
│   ├── OWASP Top 10 protection
│   ├── Input validation
│   └── SQL injection prevention
├── Data Security
│   ├── Encryption at rest/transit
│   ├── Key management
│   └── Data masking
└── Monitoring & Response
    ├── SIEM integration
    ├── SOC operations
    └── Incident response
```

Security Monitoring:

- 24/7 Security Operations Center (SOC)
- Real-time threat intelligence feeds
- Automated incident response workflows
- Vulnerability management program
- Regular penetration testing

7.11 Audit & Logging Requirements

Audit Trail Requirements:

- All user actions logged with timestamps
- Immutable audit records using blockchain/cryptographic hashing
- Real-time audit log streaming to SIEM
- Audit log retention for 7 years (regulatory requirement)
- Automated anomaly detection on audit patterns

Compliance Monitoring:

- Automated compliance rule checking
- Real-time policy violation alerts
- Regulatory reporting automation
- Compliance dashboard for management oversight
- Third-party audit support and evidence collection

8. Integration Requirements

Requirements

8.1 External System Integrations

8.1.1 Payment Gateway Integrations

Integration	Type	Protocol	Purpose	Priority
bKash API	Payment Gateway	REST/Webhook	Premium payments, claim settlements	M1
Nagad API	Payment Gateway	REST/Webhook	Premium payments, claim settlements	M2
Bangladesh Bank	Payment Gateway	ISO 8583	Bank transfers, regulatory reporting	M2
NID Verification API	Government Service	REST/SOAP	Identity verification	M1
Mobile Number Verification	Government Service	REST	Phone number validation	M1
SMS Gateway	Communication	REST	Notifications and OTP delivery	M2
Email Service	Communication	SMTP/API	Email notifications and documents	M1
Hospital EHR Systems	Healthcare	HL7 FHIR	Medical record integration	D
Weather API	Risk Assessment	REST	Environmental risk monitoring	M3
WhatsApp Business	Communication	API	Customer service and notifications	M3

8.1.2 Integration Details

bKash Payment Integration

- API Endpoints: Payment initiation, verification, refund, account inquiry
- Authentication: OAuth 2.0 with client credentials flow
- Rate Limits: 100 requests/minute per API key
- Transaction Timeout: 5 seconds connection, 15 seconds read
- Webhook Support: Payment confirmation callback to /webhooks/bkash
- Error Handling: Retry logic with exponential backoff (3 attempts: 1s, 3s, 9s)
- Cost: Transaction fee 1.5% (to be negotiated with merchant agreement)
- Testing: Sandbox environment available at https://tokenized.sandbox.bka.sh
- Mock Service: JSON-based mock required for local development
- Fallback: Queue payment for manual processing if API down >5 minutes

Nagad & Rocket Integration

- Similar specifications as bKash with provider-specific endpoints
- Fallback Mechanism: If primary MFS fails, auto-retry with alternate MFS within 30 seconds
- Health Check: Monitor MFS availability every 60 seconds
- Load Balancing: Distribute payment load across available providers

NID Verification API

- Provider: Bangladesh Election Commission API / Third-party aggregator (PORICHOY - TBD)
- API Endpoints: /verify-nid, /get-nid-details, /face-match
- Authentication: API key + IP whitelist + TLS 1.3
- Rate Limits: 1000 verifications/day (Basic tier), 10,000/day (Premium tier)
- Response Time: <3 seconds average, 10 seconds timeout
- Data Returned: Name (English/Bengali), Father/Mother name, DOB, Address, Photo (Base64)
- Cost: 5-10 BDT per verification (volume-based pricing)
- Fallback: Manual verification queue when API unavailable (notify admin within 2 minutes)
- Mock Service: JSON-based mock with 100 sample NID records for testing
- Compliance: Store verification logs for 20 years as per IDRA requirement
- Data Privacy: NID data encrypted at rest, access logged

Hospital EHR (HL7 FHIR) Integration

- Standard: HL7 FHIR R4 (Fast Healthcare Interoperability Resources)
- FHIR Resources Used:

  - Patient (demographics)
  - Encounter (admission/discharge)
  - Condition (diagnoses)
  - Procedure (treatments)
  - MedicationRequest (prescriptions)
  - DiagnosticReport (lab results, imaging)

- Authentication: OAuth 2.0 + JWT tokens, refresh every 30 minutes
- Endpoints:

  - GET /Patient/{id} - Patient lookup
  - POST /Claim - Submit cashless claim
  - GET /Claim/{id} - Check claim status

- Connection Timeout: 5 seconds
- Read Timeout: 15 seconds

- Fallback Behavior:

  - If timeout → Queue for manual verification

  - Send SMS to hospital focal point: "System unavailable, manual claim processing required"

  - Notify InsureTech support team via Slack/email

- Data Mapping: Custom FHIR profile for Bangladesh healthcare context
- Consent Management: Patient consent workflow (digital signature) before EHR access
- Participating Hospitals:

  - Phase M1: LabAid Hospitals (5 locations)

  - Phase M2+: Expand to 20+ partner hospitals

- Testing: FHIR test server with synthetic patient data

SMS Gateway Integration

- Provider: Twilio (international) / Bangladesh SMS Provider (local - TBD)
- Use Cases: OTP delivery, payment confirmation, claim status updates, policy renewal reminders
- Delivery Rate Target: >95%
- Delivery Status Tracking: Webhook for delivery confirmation
- Cost Optimization: Batching, template caching, priority queuing
- Rate Limits: 100 messages/second

WhatsApp Business API

- Message Templates: Pre-approved templates for policy confirmation, claim updates
- Opt-in/Opt-out Workflow: User consent required, unsubscribe link in messages
- Rate Limits: 1000 conversations/day (business tier)
- Cost: Per-conversation pricing (varies by country)
- Use Cases: Rich media policy documents, claim photo uploads, customer support chat

8.2 Internal Service Communications

All microservices communicate via gRPC using Protocol Buffers for type safety, performance, and cross-language compatibility:

Benefits of gRPC:

- ✅ Strong typing with Protocol Buffers
- ✅ HTTP/2 multiplexing (multiple requests over single connection)
- ✅ Bi-directional streaming support
- ✅ Built-in load balancing and health checking
- ✅ Language-agnostic (Go, C#, Python, Node.js)
- ✅ 7-10x faster than REST JSON for internal communication

Service Discovery: Consul for service registry and health checks

Load Balancing: Client-side load balancing with round-robin strategy

Timeout Configuration: 30 seconds for standard RPCs, 5 minutes for long-running operations

```
// Insurance Engine Service
service InsuranceEngineService {
  rpc IssuePolicy(IssuePolicyRequest) returns (IssuePolicyResponse);
  rpc CalculatePremium(CalculatePremiumRequest) returns (CalculatePremiumResponse);
  rpc ProcessRenewal(ProcessRenewalRequest) returns (ProcessRenewalResponse);
  rpc SubmitClaim(SubmitClaimRequest) returns (SubmitClaimResponse);
}

// Payment Service
service PaymentService {
  rpc ProcessPayment(ProcessPaymentRequest) returns (ProcessPaymentResponse);
  rpc RefundPayment(RefundPaymentRequest) returns (RefundPaymentResponse);
  rpc GetPaymentStatus(GetPaymentStatusRequest) returns (GetPaymentStatusResponse);
}

// Partner Management Service
service PartnerManagementService {
  rpc OnboardPartner(OnboardPartnerRequest) returns (OnboardPartnerResponse);
  rpc RegisterAgent(RegisterAgentRequest) returns (RegisterAgentResponse);
  rpc CalculateCommission(CalculateCommissionRequest) returns (CalculateCommissionResponse);
}
```

8.3 Event-Driven Architecture

Kafka Event Streaming:

- Policy Events: PolicyIssued, PolicyRenewed, PolicyCancelled, PremiumPaid
- Claim Events: ClaimSubmitted, ClaimApproved, ClaimSettled, ClaimRejected
- Payment Events: PaymentProcessed, PaymentFailed, RefundIssued
- User Events: UserRegistered, KYCCompleted, ProfileUpdated

Event Processing Patterns:

- Event Sourcing: Critical business events for audit and replay
- CQRS: Separate command and query models for complex aggregates
- Saga Pattern: Distributed transaction management across services
- Event Streaming: Real-time analytics and monitoring

9. Performance & Monitoring

9.1 Performance Benchmarks

Metric	Baseline Target	Peak Load Target	Measurement Method
Category 1 API (gRPC)	< 100ms	< 150ms	APM tools (New Relic/Datadog)
Category 2 API (GraphQL)	< 2 seconds	< 3 seconds	GraphQL monitoring
Category 3 API (REST)	< 200ms	< 300ms	API gateway monitoring
Public API	< 1 second	< 1.5 seconds	Public endpoint monitoring
Mobile App Startup	< 5 seconds	< 7 seconds	Device testing
PostgreSQL Query	< 100ms for 95%	< 150ms for 95%	Database monitoring
TigerBeetle Transaction	< 10ms	< 20ms	Financial system monitoring

9.2 Capacity Planning

Component	Current Capacity	12-Month Target	24-Month Target	Scaling Strategy
Concurrent Users	1,000	5,000	10,000	Auto-scaling with CloudWatch metrics
API Requests/Second	100	1,000	5,000	gRPC microservices scaling
Database Connections	100 (PostgreSQL)	500	2,000	PgBouncer connection pooling
TigerBeetle TPS	1,000	10,000	50,000	TigerBeetle cluster scaling
Storage (TB)	1	10	50	Auto-scaling object storage
Policy Documents	10,000	500,000	2,000,000	Distributed storage with archival

9.3 Monitoring & Observability

Monitoring Stack:

- Prometheus: Metrics collection and alerting
- Grafana: Visualization and dashboards
- Jaeger: Distributed tracing
- ELK Stack: Centralized logging (Elasticsearch, Logstash, Kibana)

- New Relic/DataDog: Application performance monitoring

Key Metrics:

```
Business Metrics:
  - policies_issued_per_hour
  - claims_processed_per_hour
  - premium_collection_rate
  - customer_satisfaction_score
  - partner_performance_metrics

Technical Metrics:
  - api_response_times
  - database_connection_pool
  - memory_usage_per_service
  - cpu_utilization
  - network_latency

Security Metrics:
  - authentication_failures
  - suspicious_activity_detection
  - data_access_patterns
  - security_incident_count
```

9.4 Alerting & Incident Response

Metric	Threshold	Alert Level	Action
API Response Time	> 1 second (95th percentile)	Warning	Auto-scale services
Database Connections	> 80% pool utilization	Warning	Scale database
Memory Usage	> 85% per service	Critical	Restart service
Disk Space	> 90% utilization	Critical	Add storage capacity
Authentication Failures	> 100 failed attempts/minute	Security	Block suspicious IPs
Payment Failures	> 5% failure rate	Critical	Alert payment team
System Downtime	> 5 minutes	Critical	Activate incident response

Incident Response Process:

- Detection: Automated monitoring alerts
- Assessment: On-call engineer triages severity
- Response: Escalation based on impact and urgency
- Resolution: Fix implementation and verification
- Communication: Status updates to stakeholders
- Post-Mortem: Root cause analysis and improvements

10. Support & Maintenance

10.1 Support Model

Support Level	Scope	Availability	Response SLA
L1 - Customer Support	Basic inquiries, password resets, general guidance	24/7	< 5 minutes
L2 - Technical Support	Application issues, payment problems, account issues	Business hours	< 30 minutes
L3 - Engineering Support	System bugs, performance issues, integrations	Business hours	< 2 hours
L4 - Critical Issues	System outages, security incidents, data corruption	24/7	< 15 minutes

Support Channels:

- Mobile App: In-app chat and support tickets
- Web Portal: Self-service help center and live chat
- Phone: Dedicated support hotline (Bengali/English)
- WhatsApp: Business account for basic inquiries
- Email: Support email with ticket tracking

10.2 Maintenance Windows

Scheduled Maintenance:

- Daily: Database optimization and log rotation (2:00 AM - 3:00 AM BST)
- Weekly: Security updates and patches (Sunday 1:00 AM - 3:00 AM BST)
- Monthly: Major updates and feature releases (First Saturday 10:00 PM - 2:00 AM BST)
- Quarterly: Infrastructure upgrades and capacity planning

Emergency Maintenance:

- Critical security patches: Within 4 hours of availability
- System outages: Immediate response and resolution
- Data corruption issues: Emergency procedures activated

10.3 Change Management

Deployment Process:

```
Development → Testing → Staging → Production

Development:
├── Feature branches
├── Unit testing
├── Code review
└── Integration testing

Staging:
├── User acceptance testing
├── Performance testing
├── Security testing
└── Rollback verification

Production:
├── Blue-green deployment
├── Canary releases
├── Health checks
└── Rollback procedures
```

Release Management:

- Hotfixes: Critical bug fixes deployed within 2 hours
- Minor Releases: Weekly feature releases with 48-hour notice
- Major Releases: Monthly major updates with 1-week notice
- Emergency Releases: Security patches with minimal notice

11. Acceptance Criteria & Test Requirements

11.1 Testing Strategy

Testing Pyramid:

```
              /\
             /  \
            /    \
           /  E2E \
          /________\
         /          \
        /            \
       /  Integration \
      /________________\
     /                  \
    /                    \
   /    Unit Tests       \
  /______________________  \
```

Test Coverage Requirements:

- Unit Tests: 80% code coverage minimum
- Integration Tests: All API endpoints and service interactions
- End-to-End Tests: Complete user journeys and business workflows
- Performance Tests: Load, stress, and scalability testing
- Security Tests: Vulnerability scans and penetration testing

11.2 Test Types & Responsibilities

Test Type	Coverage Target	Responsibility
Unit Testing	80% code coverage	Development teams
Integration Testing	All service interfaces	QA team
API Testing	100% endpoint coverage	Automation team
UI Testing	Critical user paths	QA team
Performance Testing	Load and stress scenarios	DevOps team
Security Testing	OWASP compliance	Security team
Accessibility Testing	WCAG 2.1 AA compliance	UX team
Compliance Testing	IDRA/BFIU requirements	Compliance team

11.3 Critical Business Workflow Validation

Workflow	Acceptance Criteria	Success Metrics
User Registration	Phone-based registration with OTP validation completes successfully	>95% completion rate
KYC Verification	Document upload and verification process completes within 5 minutes	>90% automated approval
Policy Purchase	End-to-end purchase flow from product selection to policy issuance	>99% transaction success
Payment Processing	Multiple payment methods with real-time confirmation	>99.5% payment success
Claim Submission	Claim initiation with document upload and status tracking	<3 minutes submission time
Policy Renewal	Automated and manual renewal workflows	>95% renewal completion

11.4 API Performance Testing

API Category	Load Profile	Success Criteria	Expected Performance
Category 1 (gRPC)	1000 concurrent requests	<100ms response time	High-throughput internal communication
Category 2 (GraphQL)	500 concurrent requests	<2s response time	Mobile-optimized data fetching
Category 3 (REST)	100 concurrent requests	<200ms response time	Standard 3rd party integration
Public API	50 concurrent requests	<1s response time	Public product search

11.5 FR → Test Case Mapping (MD FEEDBACK)

FR-ID	Test Case ID	Test Scenario	Expected Result	Test Type
FR-001	TC-001	Valid Bangladesh phone registration	OTP sent within 60s	Integration
FR-004	TC-002	Duplicate NID registration attempt	Error message displayed	Functional
FR-033	TC-003	End-to-end purchase with bKash	Policy issued within 30s	E2E
FR-051	TC-004	Joint approval (BizAdmin+Focal)	Claim approved only after both	Workflow
FR-129	TC-005	Insurer API failure during quote	Cached rate used + customer notified	Resilience

11.6 Test Environments

Environment Strategy:

```
Production ← Staging ← UAT ← Integration ← Development
    ↑           ↑        ↑         ↑            ↑
Real data   Prod-like  Business  Service     Feature
Security    Data       Testing   Testing     Development
```

Environment Specifications:

- Development: Individual developer environments with mock data
- Integration: Shared environment for service integration testing
- UAT: Business user acceptance testing with sanitized production data
- Staging: Production-like environment for final validation
- Production: Live environment with real customer data

12. Traceability Matrix & Change Control

12.1 Requirements Traceability

Business Objective	Related Functional Requirements	Success Metrics
Digital Onboarding: 40,000 policies by 2026	FR-001 to FR-016, FR-033 to FR-040	Monthly policy acquisition rate
API Performance Optimization	FR-107 to FR-118, NFR-008 to NFR-011	API response time metrics
Financial Transaction Integrity	FR-121 (TigerBeetle), SEC-003 (PCI-DSS)	Transaction accuracy and speed
Regulatory Compliance	SEC-011 to SEC-020 (IDRA/AML/CFT)	Audit compliance score
Partner Management Excellence	FR-011 (Focal Person), FR-086 to FR-092	Number of active partners
Claims Efficiency	FR-041 to FR-058, FR-133 to FR-137	Average claim TAT

12.2 Change Control Process

Approval Hierarchy:

- Dev submits change request
- Repository Admin reviews code changes
- Database Admin reviews data model impact
- System Admin reviews infrastructure impact
- Business Admin approves business impact
- Focal Person approves partner-related changes

14. Appendices

Note: Proto schema definitions and workflow examples are in Appendix A and B (auto-generated from actual files).

14.1 Glossary of Terms

Business Terms

Term	Definition
Policyholder	Individual or entity that purchases and owns an insurance policy
Insured	Person or entity covered by the insurance policy (may differ from policyholder)
Nominee	Designated beneficiary who receives claim proceeds
Premium	Payment made for insurance coverage
Sum Insured	Maximum amount payable under the policy
Deductible	Amount policyholder must pay before insurance coverage begins
Copay	Fixed amount paid by insured for specific covered services
Underwriting	Process of evaluating risk and determining premium
Claim	Request for payment under an insurance policy
Settlement	Payment of approved claim amount
Lapse	Policy termination due to non-payment of premium
Grace Period	Extended time after premium due date before policy lapses
Renewal	Extension of policy coverage for additional term
Rider	Additional coverage option added to base policy
Exclusion	Circumstances or conditions not covered by policy

Technical Terms

Term	Definition
Proto3	Protocol Buffers version 3 - Google's data serialization format
gRPC	High-performance RPC framework using HTTP/2
CQRS	Command Query Responsibility Segregation pattern
Event Sourcing	Storing state changes as sequence of events
VSA	Vertical Slice Architecture - organizing code by feature
Hypertable	TimescaleDB table optimized for time-series data
Materialized View	Precomputed query results stored as table
Circuit Breaker	Fault tolerance pattern preventing cascading failures
Idempotency	Operation producing same result when called multiple times
JWT	JSON Web Token for stateless authentication

14.2 Reference Documents

External References:

- IDRA Insurance Act 2010
- Bangladesh Insurance Rules 2011
- Digital Security Act 2018

- PCI-DSS 3.2.1 Standards
- ISO 27001:2013 Information Security

Appendix A - API Architecture Diagram

```
┌──────────────────────────────────────────────────────────────────────────────┐
│                          CLOUDFLARE PROXY                                    │
└──────────────────────────────────────────────────────────────────────────────┘
                                │
                                ▼
┌──────────────────────────────────────────────────────────────────────────────┐
│                          NGINX GATEWAY                                       │
└──────────────────────────────────────────────────────────────────────────────┘
                                │
                                ▼
┌──────────────────────────────────────────────────────────────────────────────┐
│  PUBLIC API (REST/JSON) │ CATEGORY 2 (GraphQL + JWT)                         │
│  - Product Search       │ - Customer Device                                  │
│  - Product List         │ - Mobile Apps                                      │
└──────────────────────────────────────────────────────────────────────────────┘
                                │
                                ▼
                        ┌──────────────────┐
                        │  API GATEWAY     │
                        │  (OAuth2 + JWT)  │
                        └──────────────────┘
                                │
                                ▼
    ┌──────────────────────────────────────────────────────────────────────┐
    │                          │                          │
    ▼                          ▼                          ▼
┌──────────┐  ┌──────────────────────────┐  ┌──────────────────────┐
│CAT 3     │  │      CATEGORY 1          │  │    INTERNAL          │
│REST API  │  │  (gRPC + ProtoBuf)       │  │   MICROSERVICES      │
│3rd       │  │  Microservices           │  │    (Kafka            │
│Party     │  │  Communication           │  │    Orchestrated)     │
└──────────┘  └──────────────────────────┘  └──────────────────────┘
```

Appendix B - Stakeholder Hierarchy

```
System Admin (Cloud/IAM Root)
    │
    ├── Repository Admin (Code/Deploy)
    │
    ├── Database Admin (Data Management)
    │
    ├── Business Admin (Business Operations)
    │   │
    │   └── Focal Person (Partner Bridge) ★ KEY ROLE
    │       │
    │       └── Partner Admin (Tenant Root)
    │           │
    │           ├── Insurer Agents (Partner Staff)
    │           └── Insurer Underwriters (API Users)
    │
    ├── Dev (Development)
    │
    └── Support/Call Centre (Customer Assistance)
```

Appendix C - Claims Approval Workflow

Workflow Diagram:

```
┌──────────────────────┐
│ Customer submits │
│ claim via app    │
└──────────────────────┘
        │
        ▼
┌──────────────────────┐
│ System validates │
│ and screens      │
└──────────────────────┘
        │
        ▼
    ┌──────────┐
    │Amount? │
    └──────────┘
        │
    ┌───┴──────────┬──────────┬──────────┐
    │              │          │          │
    ▼              ▼          ▼          ▼
0-10K     10K-50K     50K-2L      2L+
    │              │          │          │
    ▼              ▼          ▼          ▼
Auto/L1     L2 Mgr    L3 Joint     Board
Officer                BA+FP
    │              │          │          │
    └──────┬───────┴──────────┴──────────┘
        │          │
        ▼          ▼
    Approved     Rejected
        │          │
        ▼          ▼
    Payment     Notification
    Process     to Customer
```

Appendix D - Requirements Traceability Matrix

Business Objective to Requirements Mapping:

Business Objective	Related Functional Requirements	Success Metrics
Digital Onboarding: 40,000 policies by 2026	FR-001 to FR-016, FR-033 to FR-040	Monthly policy acquisition rate
API Performance Optimization	FR-107 to FR-118, NFR-008 to NFR-011	API response time metrics
Financial Transaction Integrity	FR-121 (TigerBeetle), SEC-003 (PCI-DSS)	Transaction accuracy and speed
Regulatory Compliance	SEC-011 to SEC-020 (IDRA/AML/CFT)	Audit compliance score
Partner Management Excellence	FR-011 (Focal Person), FR-086 to FR-092	Number of active partners
Claims Efficiency	FR-041 to FR-058, FR-133 to FR-137	Average claim TAT

Change Control Process:

Approval Hierarchy:

- Dev submits change request
- Repository Admin reviews code changes
- Database Admin reviews data model impact
- System Admin reviews infrastructure impact
- Business Admin approves business impact
- Focal Person approves partner-related changes

Summary Statistics:

- Total Functional Requirements: 150 (FR-001 to FR-150)
- Total Non-Functional Requirements: 45 (NFR-001 to NFR-045)
- Total IDRA Compliance Requirements: 10 (IDRA-001 to IDRA-010)
- Total BFIU Compliance Requirements: 10 (BFIU-001 to BFIU-010)
- Total AML Monitoring Rules: 10 (TM-001 to TM-010)

By Priority:

- M1 (Must Have - Phase 1): 58 requirements
- M2 (Must Have - Phase 2): 45 requirements
- D (Desirable): 32 requirements
- F (Future): 15 requirements

By Function Group:

- User Management (FG-001): 8 requirements

- Product Management (FG-002): 6 requirements
- Policy Lifecycle (FG-003): 8 requirements
- Claims Management (FG-004): 8 requirements
- Partner & Agent Management (FG-005): 8 requirements
- Payment Processing (FG-006): 8 requirements
- Customer Support (FG-007): 7 requirements
- Notifications (FG-008): 6 requirements
- IoT Integration (FG-009): 4 requirements
- Analytics & Reporting (FG-010): 5 requirements
- Audit & Logging (FG-011): 4 requirements
- Integration & APIs (FG-012): 5 requirements

Appendix E - Technology Stack Summary

Programming Languages:

- Go: Microservices backbone (Gateway, Auth, Storage, IoT)
- C# .NET 8: Business logic (Insurance Engine, Partner Management)
- Node.js: Payment processing and customer support
- Python: AI/ML and document processing
- TypeScript/React: Web interfaces and admin portals
- React Native: Mobile applications

Data & Persistence:

- Protocol Buffers: All service contracts and data models
- PostgreSQL: Transactional data and business logic
- MongoDB: Product catalog and document metadata
- Redis: Caching and session management
- Apache Kafka: Event streaming and audit trails

Infrastructure:

- Docker & Kubernetes: Containerization and orchestration
- AWS/Azure: Cloud platform and managed services
- Prometheus/Grafana: Monitoring and alerting
- Jaeger: Distributed tracing and observability

Appendix F - Compliance Checklist

IDRA Requirements Checklist:

- [ ] Digital product approval documentation
- [ ] Customer data protection policies
- [ ] Policy issuance standards compliance
- [ ] Claims processing procedures
- [ ] Financial reporting capabilities

- [ ] Agent licensing and training systems
- [ ] Marketing compliance monitoring
- [ ] Risk management frameworks
- [ ] Audit trail systems
- [ ] Regulatory change management

BFIU AML Checklist:

- [ ] Customer due diligence (CDD) procedures
- [ ] Enhanced due diligence (EDD) for high-risk customers
- [ ] Suspicious transaction monitoring systems
- [ ] Cash transaction reporting mechanisms
- [ ] Wire transfer monitoring capabilities
- [ ] PEP screening integration
- [ ] Sanctions list screening
- [ ] AML record retention policies
- [ ] Employee training programs
- [ ] Compliance reporting dashboards

Appendix G - Integration Endpoints

External API Integrations:

```
bKash Merchant API:
  Base URL: https://api.bkash.com/v1/
  Authentication: Bearer token
  Key Endpoints:
    - POST /payments/create
    - POST /payments/execute
    - GET /payments/{paymentID}

Nagad Merchant API:
  Base URL: https://api.nagad.com.bd/api/dfs/
  Authentication: API key + signature
  Key Endpoints:
    - POST /check-out/initialize
    - POST /check-out/complete
    - GET /verify/payment/{paymentRef}

Government NID API:
  Base URL: https://api.nidw.gov.bd/v1/
  Authentication: Government issued certificates
  Key Endpoints:
    - POST /verify/nid
    - GET /citizen/details/{nid}
```

Appendix H: Proto Schema Definitions

Note: This appendix is automatically generated from actual proto files in proto/insuretech/

A.1 Authentication Domain (insuretech/authn/)

A.1.1 User Entity (authn/entity/v1/user.proto)

```
syntax = "proto3";

package insuretech.authn.entity.v1;

option go_package = "github.com/labaid/insuretech/proto/authn/entity/v1;authnv1";
option csharp_namespace = "Insuretech.Authn.Entity.V1";

import "google/protobuf/timestamp.proto";

// User represents a registered user in the system
message User {
  string user_id = 1;                              // UUID
  string mobile_number = 2;                        // +880 1XXX XXXXXX
  string email = 3;                                // Optional
  string password_hash = 4;                        // bcrypt hash
  UserStatus status = 5;
  google.protobuf.Timestamp created_at = 6;
  google.protobuf.Timestamp updated_at = 7;
  google.protobuf.Timestamp last_login_at = 8;
  string created_by = 9;
  int32 login_attempts = 10;                       // Failed login counter
  google.protobuf.Timestamp locked_until = 11;     // Account lockout time
}

enum UserStatus {
  USER_STATUS_UNSPECIFIED = 0;
  USER_STATUS_PENDING_VERIFICATION = 1;
  USER_STATUS_ACTIVE = 2;
  USER_STATUS_SUSPENDED = 3;
  USER_STATUS_LOCKED = 4;
  USER_STATUS_DELETED = 5;
}

// UserProfile stores additional user information
message UserProfile {
  string user_id = 1;
  string full_name = 2;
  google.protobuf.Timestamp date_of_birth = 3;
  Gender gender = 4;
  string occupation = 5;
  Address address = 6;
  string nid_number = 7;                           // National ID
  string profile_photo_url = 8;
  bool kyc_verified = 9;
  google.protobuf.Timestamp kyc_verified_at = 10;
}

enum Gender {
  GENDER_UNSPECIFIED = 0;
```

```
  GENDER_MALE = 1;
  GENDER_FEMALE = 2;
  GENDER_OTHER = 3;
}

message Address {
  string address_line1 = 1;
  string address_line2 = 2;
  string city = 3;
  string district = 4;
  string division = 5;
  string postal_code = 6;
  string country = 7;                              // Default: Bangladesh
}
```

A.1.2 Session Entity (authn/entity/v1/session.proto)

```
syntax = "proto3";

package insuretech.authn.entity.v1;

option go_package = "github.com/labaid/insuretech/proto/authn/entity/v1;authnv1";
option csharp_namespace = "Insuretech.Authn.Entity.V1";

import "google/protobuf/timestamp.proto";

// Session represents user authentication session
message Session {
  string session_id = 1;                           // UUID
  string user_id = 2;
  string access_token = 3;                         // JWT
  string refresh_token = 4;                        // JWT
  google.protobuf.Timestamp access_token_expires_at = 5;   // 15 minutes
  google.protobuf.Timestamp refresh_token_expires_at = 6;  // 7 days
  string ip_address = 7;
  string user_agent = 8;
  string device_id = 9;
  DeviceType device_type = 10;
  google.protobuf.Timestamp created_at = 11;
  google.protobuf.Timestamp last_activity_at = 12;
  bool is_active = 13;
}

enum DeviceType {
  DEVICE_TYPE_UNSPECIFIED = 0;
  DEVICE_TYPE_WEB = 1;
  DEVICE_TYPE_MOBILE_ANDROID = 2;
  DEVICE_TYPE_MOBILE_IOS = 3;
  DEVICE_TYPE_API = 4;
}

// OTP for phone/email verification
message OTP {
  string otp_id = 1;
  string recipient = 2;                            // Phone or email
  OTPType type = 3;
  string code = 4;                                 // 6-digit code
```

```
  google.protobuf.Timestamp created_at = 5;
  google.protobuf.Timestamp expires_at = 6;        // 5 minutes validity
  int32 attempts = 7;                              // Max 3 attempts
  bool verified = 8;
  google.protobuf.Timestamp verified_at = 9;
}

enum OTPType {
  OTP_TYPE_UNSPECIFIED = 0;
  OTP_TYPE_REGISTRATION = 1;
  OTP_TYPE_LOGIN = 2;
  OTP_TYPE_PASSWORD_RESET = 3;
  OTP_TYPE_TRANSACTION = 4;
}
```

A.1.3 Authentication Events (authn/events/v1/auth_events.proto)

```
syntax = "proto3";

package insuretech.authn.events.v1;

option go_package = "github.com/labaid/insuretech/proto/authn/events/v1;authneventsv1";
option csharp_namespace = "Insuretech.Authn.Events.V1";

import "google/protobuf/timestamp.proto";

// Event: User registered
message UserRegisteredEvent {
  string event_id = 1;
  string user_id = 2;
  string mobile_number = 3;
  string email = 4;
  google.protobuf.Timestamp timestamp = 5;
  string ip_address = 6;
  string device_type = 7;
}

// Event: User logged in
message UserLoggedInEvent {
  string event_id = 1;
  string user_id = 2;
  string session_id = 3;
  google.protobuf.Timestamp timestamp = 4;
  string ip_address = 5;
  string device_type = 6;
  string user_agent = 7;
}

// Event: User logged out
message UserLoggedOutEvent {
  string event_id = 1;
  string user_id = 2;
  string session_id = 3;
  google.protobuf.Timestamp timestamp = 4;
}

// Event: Password changed
```

```
message PasswordChangedEvent {
  string event_id = 1;
  string user_id = 2;
  google.protobuf.Timestamp timestamp = 3;
  string ip_address = 4;
  string changed_by = 5;                          // user_id or "admin"
}

// Event: Account locked
message AccountLockedEvent {
  string event_id = 1;
  string user_id = 2;
  string reason = 3;                              // "failed_login" | "fraud" | "manual"
  google.protobuf.Timestamp timestamp = 4;
  google.protobuf.Timestamp locked_until = 5;
}

// Event: OTP sent
message OTPSentEvent {
  string event_id = 1;
  string otp_id = 2;
  string recipient = 3;                           // Masked: +880 1XXX ***789
  string type = 4;                                // registration, login, reset
  google.protobuf.Timestamp timestamp = 5;
  string channel = 6;                             // sms, email
}

// Event: OTP verified
message OTPVerifiedEvent {
  string event_id = 1;
  string otp_id = 2;
  string user_id = 3;
  google.protobuf.Timestamp timestamp = 4;
  int32 attempts = 5;
}
```

A.1.4 Authentication Service (authn/services/v1/auth_service.proto)

```
syntax = "proto3";

package insuretech.authn.services.v1;

option go_package = "github.com/labaid/insuretech/proto/authn/services/v1;authnservicev1";
option csharp_namespace = "Insuretech.Authn.Services.V1";

import "insuretech/authn/entity/v1/user.proto";
import "insuretech/authn/entity/v1/session.proto";

// Authentication Service
service AuthService {
  // Register new user
  rpc Register(RegisterRequest) returns (RegisterResponse);

  // Send OTP for verification
  rpc SendOTP(SendOTPRequest) returns (SendOTPResponse);

  // Verify OTP
```

```
  rpc VerifyOTP(VerifyOTPRequest) returns (VerifyOTPResponse);

  // Login with credentials
  rpc Login(LoginRequest) returns (LoginResponse);

  // Refresh access token
  rpc RefreshToken(RefreshTokenRequest) returns (RefreshTokenResponse);

  // Logout
  rpc Logout(LogoutRequest) returns (LogoutResponse);

  // Change password
  rpc ChangePassword(ChangePasswordRequest) returns (ChangePasswordResponse);

  // Reset password
  rpc ResetPassword(ResetPasswordRequest) returns (ResetPasswordResponse);

  // Validate token
  rpc ValidateToken(ValidateTokenRequest) returns (ValidateTokenResponse);
}

// Register Request
message RegisterRequest {
  string mobile_number = 1;                        // Required: +880 1XXX XXXXXX
  string email = 2;                                // Optional
  string password = 3;                             // Min 8 chars, 1 upper, 1 number, 1 special
  string device_id = 4;
  string device_type = 5;
}

message RegisterResponse {
  string user_id = 1;
  string message = 2;
  bool otp_sent = 3;
}

// Send OTP Request
message SendOTPRequest {
  string recipient = 1;                            // Mobile or email
  string type = 2;                                 // registration, login, reset
}

message SendOTPResponse {
  string otp_id = 1;
  string message = 2;
  int32 expires_in_seconds = 3;                    // 300 seconds (5 min)
}

// Verify OTP Request
message VerifyOTPRequest {
  string otp_id = 1;
  string code = 2;                                 // 6-digit code
}

message VerifyOTPResponse {
  bool verified = 1;
  string user_id = 2;
  string message = 3;
}
```

```
// Login Request
message LoginRequest {
  string mobile_number = 1;
  string password = 2;
  string device_id = 3;
  string device_type = 4;
}

message LoginResponse {
  string user_id = 1;
  string access_token = 2;
  string refresh_token = 3;
  int32 access_token_expires_in = 4;               // 900 seconds (15 min)
  int32 refresh_token_expires_in = 5;              // 604800 seconds (7 days)
  entity.v1.User user = 6;
}

// Refresh Token Request
message RefreshTokenRequest {
  string refresh_token = 1;
}

message RefreshTokenResponse {
  string access_token = 1;
  string refresh_token = 2;                        // New refresh token
  int32 access_token_expires_in = 3;
  int32 refresh_token_expires_in = 4;
}

// Logout Request
message LogoutRequest {
  string session_id = 1;
}

message LogoutResponse {
  string message = 1;
}

// Change Password Request
message ChangePasswordRequest {
  string user_id = 1;
  string old_password = 2;
  string new_password = 3;
}

message ChangePasswordResponse {
  string message = 1;
}

// Reset Password Request
message ResetPasswordRequest {
  string mobile_number = 1;
  string otp_code = 2;
  string new_password = 3;
}

message ResetPasswordResponse {
  string message = 1;
}
```

```
// Validate Token Request
message ValidateTokenRequest {
  string access_token = 1;
}

message ValidateTokenResponse {
  bool valid = 1;
  string user_id = 2;
  repeated string roles = 3;
  repeated string permissions = 4;
}
```

A.2 Policy Domain (insuretech/policy/)

A.2.1 Policy Entity (policy/entity/v1/policy.proto)

```
syntax = "proto3";

package insuretech.policy.entity.v1;

option go_package = "github.com/labaid/insuretech/proto/policy/entity/v1;policyv1";
option csharp_namespace = "Insuretech.Policy.Entity.V1";

import "google/protobuf/timestamp.proto";

// Policy represents an insurance policy
message Policy {
  string policy_id = 1;                             // UUID
  string policy_number = 2;                         // LBT-YYYY-XXXX-NNNNNN
  string product_id = 3;
  string customer_id = 4;
  string partner_id = 5;                            // Optional
  string agent_id = 6;                              // Optional
  PolicyStatus status = 7;
  double premium_amount = 8;
  double sum_insured = 9;
  int32 tenure_months = 10;
  google.protobuf.Timestamp start_date = 11;
  google.protobuf.Timestamp end_date = 12;
  google.protobuf.Timestamp issued_at = 13;
  google.protobuf.Timestamp created_at = 14;
  google.protobuf.Timestamp updated_at = 15;
  string policy_document_url = 16;
  repeated Nominee nominees = 17;
  repeated Rider riders = 18;
}

enum PolicyStatus {
  POLICY_STATUS_UNSPECIFIED = 0;
  POLICY_STATUS_PENDING_PAYMENT = 1;
  POLICY_STATUS_ACTIVE = 2;
  POLICY_STATUS_GRACE_PERIOD = 3;
  POLICY_STATUS_LAPSED = 4;
  POLICY_STATUS_SUSPENDED = 5;
  POLICY_STATUS_CANCELLED = 6;
  POLICY_STATUS_EXPIRED = 7;
```

```
}

message Nominee {
  string nominee_id = 1;
  string full_name = 2;
  string relationship = 3;
  double share_percentage = 4;                      // Must sum to 100
  google.protobuf.Timestamp date_of_birth = 5;
  string nid_number = 6;
  string phone_number = 7;
}

message Rider {
  string rider_id = 1;
  string rider_name = 2;
  double premium_amount = 3;
  double coverage_amount = 4;
}

// Applicant information
message Applicant {
  string full_name = 1;
  google.protobuf.Timestamp date_of_birth = 2;
  string nid_number = 3;
  string occupation = 4;
  double annual_income = 5;
  string address = 6;
  HealthDeclaration health_declaration = 7;
}

message HealthDeclaration {
  bool has_pre_existing_conditions = 1;
  repeated string conditions = 2;
  bool is_smoker = 3;
  string blood_group = 4;
}
```

A.3 Claims Domain (insuretech/claims/)

A.3.1 Claim Entity (claims/entity/v1/claim.proto)

```
syntax = "proto3";

package insuretech.claims.entity.v1;

option go_package = "github.com/labaid/insuretech/proto/claims/entity/v1;claimsv1";
option csharp_namespace = "Insuretech.Claims.Entity.V1";

import "google/protobuf/timestamp.proto";

// Claim represents an insurance claim
message Claim {
  string claim_id = 1;                              // UUID
  string claim_number = 2;                          // CLM-YYYY-XXXX-NNNNNN
  string policy_id = 3;
  string customer_id = 4;
```

```
  ClaimStatus status = 5;
  ClaimType type = 6;
  double claimed_amount = 7;
  double approved_amount = 8;
  double settled_amount = 9;
  google.protobuf.Timestamp incident_date = 10;
  string incident_description = 11;
  repeated ClaimDocument documents = 12;
  repeated ClaimApproval approvals = 13;
  google.protobuf.Timestamp submitted_at = 14;
  google.protobuf.Timestamp approved_at = 15;
  google.protobuf.Timestamp settled_at = 16;
  google.protobuf.Timestamp created_at = 17;
  google.protobuf.Timestamp updated_at = 18;
  string rejection_reason = 19;
  FraudCheckResult fraud_check = 20;
}

enum ClaimStatus {
  CLAIM_STATUS_UNSPECIFIED = 0;
  CLAIM_STATUS_SUBMITTED = 1;
  CLAIM_STATUS_UNDER_REVIEW = 2;
  CLAIM_STATUS_PENDING_DOCUMENTS = 3;
  CLAIM_STATUS_APPROVED = 4;
  CLAIM_STATUS_REJECTED = 5;
  CLAIM_STATUS_SETTLED = 6;
  CLAIM_STATUS_DISPUTED = 7;
}

enum ClaimType {
  CLAIM_TYPE_UNSPECIFIED = 0;
  CLAIM_TYPE_HEALTH_HOSPITALIZATION = 1;
  CLAIM_TYPE_HEALTH_SURGERY = 2;
  CLAIM_TYPE_MOTOR_ACCIDENT = 3;
  CLAIM_TYPE_MOTOR_THEFT = 4;
  CLAIM_TYPE_TRAVEL_MEDICAL = 5;
  CLAIM_TYPE_TRAVEL_BAGGAGE_LOSS = 6;
  CLAIM_TYPE_DEVICE_DAMAGE = 7;
  CLAIM_TYPE_DEVICE_THEFT = 8;
  CLAIM_TYPE_DEATH = 9;
}

message ClaimDocument {
  string document_id = 1;
  string document_type = 2;                        // bill, prescription, police_report, etc.
  string file_url = 3;
  string file_hash = 4;                            // SHA-256
  google.protobuf.Timestamp uploaded_at = 5;
  bool verified = 6;
  string verified_by = 7;
}

message ClaimApproval {
  string approver_id = 1;
  string approver_role = 2;                        // Claims Officer, Manager, Admin
  ApprovalDecision decision = 3;
  double approved_amount = 4;
  string notes = 5;
  google.protobuf.Timestamp approved_at = 6;
}
```

```
enum ApprovalDecision {
  APPROVAL_DECISION_UNSPECIFIED = 0;
  APPROVAL_DECISION_PENDING = 1;
  APPROVAL_DECISION_APPROVED = 2;
  APPROVAL_DECISION_REJECTED = 3;
  APPROVAL_DECISION_NEEDS_MORE_INFO = 4;
}

message FraudCheckResult {
  double fraud_score = 1;                          // 0-100
  repeated string risk_factors = 2;
  bool flagged = 3;
  string reviewed_by = 4;
  google.protobuf.Timestamp reviewed_at = 5;
}
```

A.4 Payment Domain (insuretech/payment/)

A.4.1 Payment Entity (payment/entity/v1/payment.proto)

```
syntax = "proto3";

package insuretech.payment.entity.v1;

option go_package = "github.com/labaid/insuretech/proto/payment/entity/v1;paymentv1";
option csharp_namespace = "Insuretech.Payment.Entity.V1";

import "google/protobuf/timestamp.proto";

// Payment represents a financial transaction
message Payment {
  string payment_id = 1;                           // UUID
  string transaction_id = 2;                       // External gateway transaction ID
  string policy_id = 3;                            // Optional (for premium)
  string claim_id = 4;                             // Optional (for claim settlement)
  PaymentType type = 5;
  PaymentMethod method = 6;
  PaymentStatus status = 7;
  double amount = 8;
  string currency = 9;                             // BDT
  string payer_id = 10;
  string payee_id = 11;
  google.protobuf.Timestamp initiated_at = 12;
  google.protobuf.Timestamp completed_at = 13;
  google.protobuf.Timestamp created_at = 14;
  string gateway = 15;                             // bKash, Nagad, SSLCommerz, etc.
  string gateway_response = 16;                    // JSON response
  string receipt_url = 17;
  int32 retry_count = 18;
}

enum PaymentType {
  PAYMENT_TYPE_UNSPECIFIED = 0;
  PAYMENT_TYPE_PREMIUM = 1;
  PAYMENT_TYPE_CLAIM_SETTLEMENT = 2;
```

```
  PAYMENT_TYPE_REFUND = 3;
  PAYMENT_TYPE_COMMISSION = 4;
}

enum PaymentMethod {
  PAYMENT_METHOD_UNSPECIFIED = 0;
  PAYMENT_METHOD_BKASH = 1;
  PAYMENT_METHOD_NAGAD = 2;
  PAYMENT_METHOD_ROCKET = 3;
  PAYMENT_METHOD_CARD = 4;
  PAYMENT_METHOD_BANK_TRANSFER = 5;
  PAYMENT_METHOD_CASH = 6;
  PAYMENT_METHOD_CHEQUE = 7;
}

enum PaymentStatus {
  PAYMENT_STATUS_UNSPECIFIED = 0;
  PAYMENT_STATUS_INITIATED = 1;
  PAYMENT_STATUS_PENDING = 2;
  PAYMENT_STATUS_PROCESSING = 3;
  PAYMENT_STATUS_SUCCESS = 4;
  PAYMENT_STATUS_FAILED = 5;
  PAYMENT_STATUS_REFUNDED = 6;
  PAYMENT_STATUS_CANCELLED = 7;
}
```

A.5 Partner Domain (insuretech/partner/)

A.5.1 Partner Entity (partner/entity/v1/partner.proto)

```
syntax = "proto3";

package insuretech.partner.entity.v1;

option go_package = "github.com/labaid/insuretech/proto/partner/entity/v1;partnerv1";
option csharp_namespace = "Insuretech.Partner.Entity.V1";

import "google/protobuf/timestamp.proto";

// Partner represents a business partner
message Partner {
  string partner_id = 1;                          // UUID
  string organization_name = 2;
  PartnerType type = 3;
  PartnerStatus status = 4;
  string trade_license = 5;
  string tin_number = 6;
  string bank_account = 7;
  string contact_email = 8;
  string contact_phone = 9;
  CommissionStructure commission = 10;
  google.protobuf.Timestamp onboarded_at = 11;
  google.protobuf.Timestamp created_at = 12;
  google.protobuf.Timestamp updated_at = 13;
  string focal_person_id = 14;                    // Assigned focal person
}
```

```
enum PartnerType {
  PARTNER_TYPE_UNSPECIFIED = 0;
  PARTNER_TYPE_HOSPITAL = 1;
  PARTNER_TYPE_MFS = 2;
  PARTNER_TYPE_ECOMMERCE = 3;
  PARTNER_TYPE_AGENT_NETWORK = 4;
  PARTNER_TYPE_CORPORATE = 5;
}

enum PartnerStatus {
  PARTNER_STATUS_UNSPECIFIED = 0;
  PARTNER_STATUS_PENDING_VERIFICATION = 1;
  PARTNER_STATUS_ACTIVE = 2;
  PARTNER_STATUS_SUSPENDED = 3;
  PARTNER_STATUS_TERMINATED = 4;
}

message CommissionStructure {
  double acquisition_rate = 1;                      // Percentage (15-25%)
  double renewal_rate = 2;                          // Percentage
  double claims_assistance_rate = 3;                // Percentage
}

// Agent under partner
message Agent {
  string agent_id = 1;
  string partner_id = 2;
  string full_name = 3;
  string phone_number = 4;
  string email = 5;
  AgentStatus status = 6;
  double commission_rate = 7;
  google.protobuf.Timestamp joined_at = 8;
}

enum AgentStatus {
  AGENT_STATUS_UNSPECIFIED = 0;
  AGENT_STATUS_ACTIVE = 1;
  AGENT_STATUS_INACTIVE = 2;
  AGENT_STATUS_SUSPENDED = 3;
}
```

Appendix I: Workflow Examples

Note: This appendix is automatically generated from example files in examples/

B.1 Authentication Workflows

Authentication Flow Example

User Registration Flow

1. User enters mobile number (+880 1XXX XXXXXX)
2. System validates format
3. System sends OTP via SMS
4. User enters 6-digit OTP code
5. System verifies OTP
6. User creates password (min 8 chars, 1 upper, 1 number, 1 special)
7. System creates user account
8. System issues JWT tokens (access + refresh)
9. User redirected to profile completion

Login Flow

1. User enters mobile number + password
2. System validates credentials
3. System checks account status (not locked)
4. System generates JWT access token (15 min) and refresh token (7 days)
5. System creates session record
6. User authenticated - redirect to dashboard

OTP Verification Example

Request:

```
POST /api/v1/auth/otp/verify
{
  "otp_id": "otp_abc123",
  "code": "123456"
}
```

Response:

```
{
  "verified": true,
  "user_id": "user_xyz789",
  "message": "OTP verified successfully"
}
```

B.2 Policy Purchase Workflow

Policy Purchase Flow Example

End-to-End Policy Purchase

Step 1: Product Selection
- User browses product catalog
- Filters by category (Health, Motor, Travel)
- Views product details
- Clicks "Buy Now"

Step 2: Applicant Information
- Full Name: "John Doe"
- DOB: 1990-05-15
- NID: 1234567890123
- Occupation: "Software Engineer"
- Annual Income: 500000 BDT
- Address: Complete address with district

Step 3: Nominee Details
- Nominee 1: Spouse (50%)
- Nominee 2: Parent (50%)
- Total share: 100%

Step 4: Premium Calculation
- Base Premium: 1,500 BDT
- Riders: +200 BDT
- Total: 1,700 BDT

Step 5: Payment
- Select method: bKash
- Enter bKash number
- Receive OTP
- Confirm payment

Step 6: Policy Issuance
- Payment confirmed
- Policy number generated: LBT-2025-0001-000123
- Policy document created (PDF with QR code)
- SMS + Email sent with policy details

Policy Number Format

```
LBT-YYYY-XXXX-NNNNNN
|   |    |    └─ Sequential number (6 digits)
|   |    └──────── Product code (4 digits)
|   └──────────────── Year (4 digits)
└──────────────────── Company prefix
```

B.3 Claims Processing Workflow

Claims Processing Workflow Example

Claim Submission Flow

Step 1: Claim Initiation
- User selects active policy
- Clicks "File Claim"
- System validates policy status (must be ACTIVE)

Step 2: Incident Details
- Incident Date: 2025-01-10
- Incident Type: Hospitalization
- Hospital Name: LabAid Hospital
- Claimed Amount: 25,000 BDT

Step 3: Document Upload
- Hospital Bill (PDF)
- Prescription (Image)
- Discharge Summary (PDF)
- System validates:
  * File size < 5MB
  * Image quality check
  * OCR extraction of bill details

Step 4: Claim Submission
- Claim Number Generated: CLM-2025-0001-000045
- Digital hash created (SHA-256)
- Notification sent to partner/insurer
- Status: SUBMITTED

Step 5: Review Process
- Auto-assigned to Claims Officer (Amount < 10K)

- OR Assigned to Claims Manager (Amount 10K-50K)
- Fraud check runs automatically

Step 6: Approval
- Approver reviews documents
- Approver adds notes
- Decision: APPROVED for 23,000 BDT (excluded non-covered items)

Step 7: Settlement
- Payment initiated via bKash
- Settlement time: 24 hours
- Customer notified
- Status: SETTLED

Claims Approval Matrix

Claimed Amount	Approval Level	Approver	TAT
0-10K	L1 Auto/Officer	System OR Claims Officer	24 Hours
10K-50K	L2 Manager	Claims Manager	3 Days
50K-2L	L3 Head	Business Admin + Focal Person	7 Days
2L+	Board	Board + Insurer Approval	15 Days

End of Appendices

Sign-off & Approval

Role	Name	Signature	Date
Insuretech	Director	_____	___/___/2025
Chief Executive Officer	CEO	_____	___/___/2025
Chief Technology Officer	CTO	_____	___/___/2025
Chief Financial Officer	CFO	_____	___/___/2025
Business Head	InsureTech	_____	___/___/2025
Project Manager	InsureTech	_____	___/___/2025
Senior Dev	LifePlus	_____	___/___/2025

Document Status

- Version: 3.10
- Date: January 2025
- Status: FINAL_DRAFT

End of Document